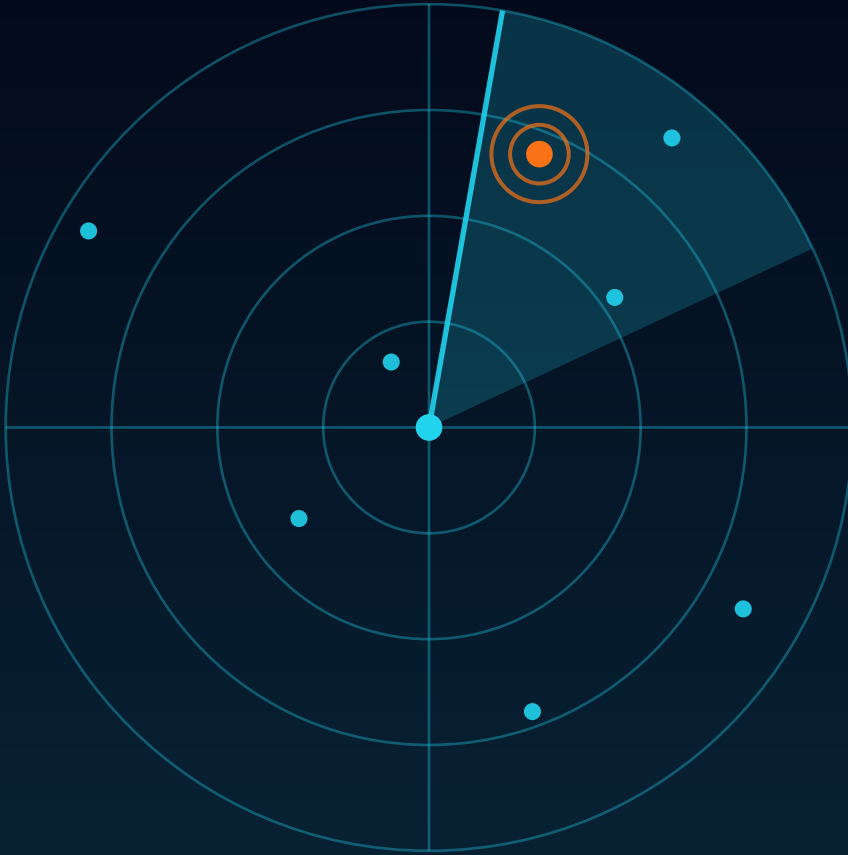




ZERO TO SOC

A Budget-Friendly Roadmap to Your
First Cyber Security Job

LEARN. DETECT. DEFEND.

SURAJ WAGH

First Edition | 2026

This page intentionally left blank

A BUDGET-FRIENDLY ROADMAP

ZERO TO SOC

Your Roadmap to a First Cyber Security Job

Fundamentals, hands-on practice, quizzes, certifications, resume, interviews and career growth for aspiring SOC analysts

LEARN. DETECT. DEFEND.

SURAJ WAGH

First Edition, 2026

Copyright and Terms of Sharing

Zero to SOC: A Budget-Friendly Roadmap to Your First Cyber Security Job

Copyright © 2026 Suraj Wagh. All rights reserved.

First Edition, October 2026.

Official tagline: **Learn. Detect. Defend.**

This book, including its text, structure, quizzes, diagrams and layout, is the original work of Suraj Wagh. Third-party sources and licences are listed in *References and Citations*.

Terms and Conditions

- **Free sharing allowed:** you may share this book with friends, students, colleagues and online communities at no charge, provided it is shared **complete and unmodified**.
- **Credit required:** keep this copyright notice and credit the author as **Suraj Wagh**.
- **No selling:** you may not sell, rent, or include this book in any paid course, paid group, subscription or product.
- **No modification:** you may not edit, remove the author's name or the tagline watermark, rebrand, or claim this work as your own.
- **No republishing:** you may not copy substantial parts into another book, website or course without written permission from the author.
- **Permission:** for any use not listed above, written permission from the author is required.
- **Termination:** permission to share ends automatically if these terms are broken.

Disclaimer

- This book is for educational purposes only and does not guarantee a job, salary or certification outcome.
- Free offers, prices, course content, standards and links belong to third parties and change often. They were checked in October 2026; confirm them on official websites before you rely on them.
- Trademarks belong to their respective owners. This book is not affiliated with or endorsed by them.
- Practice only in your own lab or on platforms that explicitly allow it. Never test systems without written permission.
- Names, IP addresses and domains in examples are fictional or reserved for documentation. Any resemblance to real ones is coincidental.
- The author is not liable for any loss or damage arising from the use of this book.

A Message from the Author

Dear reader,

Every security professional you admire once opened a terminal for the first time and understood almost nothing. Nobody is born knowing what an event ID is, how DNS works, or how to tell a harmless alert from a real attack. They learned it one lab, one mistake and one small win at a time. So can you.

You do not need a perfect start. You need a **start**. Maybe you are a fresher with a degree and no experience. Maybe you already work in an IT company and want to move into security. Maybe you have been told that cyber security is only for geniuses or for people with big budgets. It is not. It is for people who stay curious and keep practicing.

There will be days when your lab will not boot, the log will make no sense, and an interview will not go your way. Those days are not proof that you are failing. They are the job. Every analyst has spent hours staring at a screen before the answer finally clicked.

Three promises to make to yourself today:

- Practice a little every day. Thirty focused minutes beat one long weekend.
- Write down what you learn. Your notes become your write-ups, and your write-ups become your proof.
- Stay ethical. Skill without integrity is worthless in this profession.

Do not wait until you feel ready. Readiness comes from doing. Open the first chapter, start your lab, and take the next small step. The world needs more defenders, and there is a place for you among them.

With belief in you,

Suraj Wagh

India, 2026

KEY TAKEAWAYS

Learn. Detect. Defend. That is the whole journey: learn the basics, detect what is wrong, and defend what matters.

About the Author

Suraj Wagh works in an IT company in India and writes about starting a career in cyber security, beginning with Security Operations Center (SOC) analysis.

This book grew out of the questions every beginner asks: *Which certificates do I need? How do I learn with a small budget? Where do I practice? How do I get my first job?* Instead of leaving the answers in scattered notes, the author organized them into one practical path that anyone with a basic IT background can follow using free and low-cost resources.

The book is deliberately hands-on. Every chapter ends with a quiz, and the chapters point to labs, tools and videos so that readers learn by doing rather than only by reading.

TIP

Author's note: You do not need a famous college or a big budget to start. You need curiosity, a few hours a week, and the habit of practicing and documenting what you learn.

Preface

Cyber security is one of the fastest growing career fields, yet beginners often feel lost. Courses are expensive, advice is scattered, and job postings ask for years of experience for entry-level roles. This book was written to cut through the noise.

It focuses on one role: the **SOC Analyst**. This is the most accessible entry point into security, because organizations of every size need people to watch their systems, and many are willing to train beginners who show real practical ability. Once you work in a SOC, doors open to incident response, threat hunting, forensics, threat intelligence, detection engineering and even penetration testing.

What you will find inside:

- Technical foundations in networking, operating systems and security.
- Core SOC skills: logs, SIEM, triage, phishing analysis, threat intelligence, MITRE ATT&CK and Wireshark.
- A home lab guide, practice platforms and sample investigation write-ups.
- A 16-week study plan, certification advice, resume and interview preparation.
- A quiz after every chapter with an answer key, plus cheat sheets, references, a glossary and an index.

Who this book is for: engineering and IT graduates, career changers, help-desk and support staff, working IT professionals, and anyone who wants a structured, low-cost path into cyber security. You do not need prior security knowledge.

The book teaches defense. All hands-on activities are meant for your own isolated lab and for platforms that permit them. I hope it helps you land your first SOC role and, more importantly, enjoy the journey.

How to Use This Book

Reading paths

If you...	Start with
Are a complete beginner	Read from Chapter 1 in order
Have an IT degree or networking basics	Skim Part II, then focus on Parts III and IV
Already know SOC theory	Jump to Chapter 11 (lab) and Chapter 13 (write-ups)
Are ready to apply	Go to Chapters 15 to 17 and the checklists in Appendix C
Are short on time	Follow the 16-week plan in Chapter 14 and use chapters as reference

Special boxes used in this book

Box	Meaning
Key Takeaways	Summary points to remember
Try It Yourself	Hands-on exercises to do in a lab
Check Yourself	Reflection questions
Chapter Quiz	Five multiple-choice questions after each chapter; answers are in the Quiz Answer Key next to the Glossary
Watch and Learn	Video links (YouTube searches) that explain the topic
Tip / Warning	Practical advice, and safety, legal or career warnings

Citations: numbers such as [1] refer to the References and Citations page. **Links:** blue underlined text is clickable. **Blank pages:** pages marked as intentionally left blank keep each new part and section starting on a right-hand page, as in a printed book. **Practice:** reading alone will not make you employable. Do the labs, write the reports, and publish your work.

Contents

A Message from the Author	5
About the Author	6
Preface	7
How to Use This Book	8
Getting Started	11
1. Introduction to Cyber Security	13
2. What Is a Security Operations Center?	17
Technical Foundations	21
3. Networking Essentials	22
4. Operating Systems: Linux and Windows	26
5. Security Fundamentals	30
Core SOC Skills	33
6. Logs and SIEM	35
7. Alert Triage and Incident Response	39
8. Phishing Analysis	43
9. Threat Intelligence, MITRE ATT&CK and the Kill Chain	47
10. Network Analysis with Wireshark	51
Hands-On Practice	55
11. Building Your Home Lab	57
12. Practice Platforms and CTFs	60
13. Writing Investigation Reports	63
Your Career	67
14. The 16-Week Study Plan	69
15. Certifications	72
16. Resume, LinkedIn and Interviews	75
17. Job Hunt and Your First 90 Days	79
18. Career Paths and Professional Ethics	82
Appendix A: Cheat Sheets	85
Appendix B: Resource Directory	87
Appendix C: Checklists	89
References and Citations	91
Quiz Answer Key	93
Glossary	97
Index	100
A Message to Readers	103

This page intentionally left blank

PART I

Getting Started

What cyber security is, and what a Security Operations Center really does every day.

This page intentionally left blank

1. Introduction to Cyber Security

Cyber security is the practice of protecting computers, networks, applications and data from attack, damage or unauthorized access. Every organization that uses technology, from a small shop to a bank or hospital, needs it. As more of life moves online, attackers have more targets and more reasons to attack, which is why the demand for trained people keeps growing.

1.1 The CIA Triad

Almost every security decision comes back to three goals: **Confidentiality**, **Integrity** and **Availability**. When an alert fires, a good analyst asks which of the three is at risk.

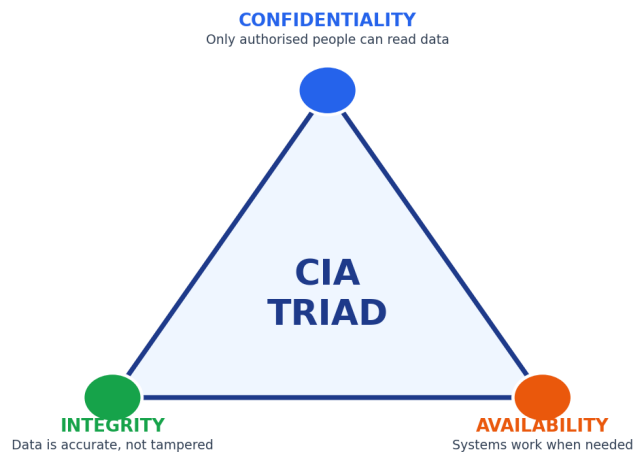


Figure 1.1: The CIA triad

Goal	Meaning	Example attack	Example defense
Confidentiality	Only authorized people can see data	Data theft, phishing for passwords	Encryption, access control, MFA
Integrity	Data stays accurate and unaltered	Tampering with records, malware changing files	Hashing, digital signatures, change monitoring
Availability	Systems and data are usable when needed	Ransomware, DDoS	Backups, redundancy, DDoS protection

1.2 Who Are the Attackers?

Knowing who attacks, and why, helps you judge how serious an alert is.

Attacker type	Motivation	Typical behavior
Script kiddies	Curiosity, fame	Use ready-made tools, noisy and unskilled
Cybercriminals	Money	Ransomware, fraud, credential theft, selling data
Hacktivists	Political or social cause	Website defacement, DDoS, data leaks
Insiders	Revenge, money, or mistakes	Misuse legitimate access; the hardest to spot
Nation-state groups (APT)	Espionage, sabotage	Patient, well funded, stealthy, long campaigns

1.3 Common Attacks You Will See

Attack	What it is
Phishing	Fake emails or messages that trick users into clicking a link, opening a file or giving credentials
Malware	Malicious software: viruses, trojans, worms, spyware, ransomware
Ransomware	Malware that encrypts files and demands payment
Brute force / credential stuffing	Trying many passwords, or leaked username-password pairs, against a login
DDoS	Flooding a service with traffic so real users cannot use it
SQL injection / web attacks	Sending malicious input to a web app to read or change its database
Man-in-the-middle	Secretly intercepting communication between two parties
Social engineering	Manipulating people (calls, messages, in person) instead of hacking systems
Supply chain attack	Compromising a trusted vendor or software update to reach many victims

1.4 Areas of Cyber Security

Cyber security is a big field. Most careers fall into these areas, and a SOC job gives you a view of almost all of them.

- **Blue team (defense):** monitoring, detection, incident response. SOC analysts work here.
- **Red team (offense):** penetration testers and ethical hackers who simulate attacks.

- **Purple team:** blue and red working together to improve detection.
- **DFIR:** digital forensics and incident response, investigating what happened.
- **GRC:** governance, risk and compliance, policies and audits.
- **Cloud and application security:** protecting cloud platforms and software.

KEY TAKEAWAYS

- Cyber security protects confidentiality, integrity and availability.
- Different attackers have different motives and skill levels.
- Most real incidents start with simple things: phishing, weak passwords, unpatched systems.
- SOC work is the best entry point because it exposes you to every area.

CHECK YOURSELF

- Name one real-world example for each part of the CIA triad.
- Why is an insider often harder to detect than an outside attacker?
- Which area of cyber security interests you most, and why?

WATCH AND LEARN

[What is cyber security explained](#) | [Types of cyber attacks](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 1 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Ransomware mainly attacks which part of the CIA triad?
 - A) Confidentiality
 - B) Authentication
 - C) Accountability
 - D) Availability
2. Which attacker is hardest to spot because they already have legitimate access?
 - A) A hacktivist
 - B) A script kiddie
 - C) An insider
 - D) A botnet
3. A leaked customer database mainly breaks which goal?
 - A) Confidentiality
 - B) Availability
 - C) Redundancy
 - D) Integrity

4. SOC analysts mainly work in which area?
- A) Application development
 - B) Blue team (defense)
 - C) GRC
 - D) Red team (offense)
5. A fake email that tricks a user into typing a password is called:
- A) A man-in-the-middle
 - B) DDoS
 - C) SQL injection
 - D) Phishing

2. What Is a Security Operations Center?

A Security Operations Center (SOC) is the team, process and technology responsible for monitoring an organization's systems around the clock, detecting attacks, and responding to them. Think of it as the control room of a company's cyber defense: screens full of alerts, analysts deciding what is real, and a plan for what to do next.

2.1 People, Process, Technology

- **People:** analysts, engineers, managers with different skill levels.
- **Process:** playbooks and runbooks that say what to do for each type of alert.
- **Technology:** SIEM, EDR, firewalls, ticketing and threat intelligence tools.

2.2 How a SOC Works



Figure 2.1: From log source to response

Systems produce logs. Collectors send them to the SIEM, which looks for suspicious patterns and raises alerts. Analysts investigate those alerts, decide whether each one is a real threat, and trigger a response.

2.3 SOC Tiers and Roles

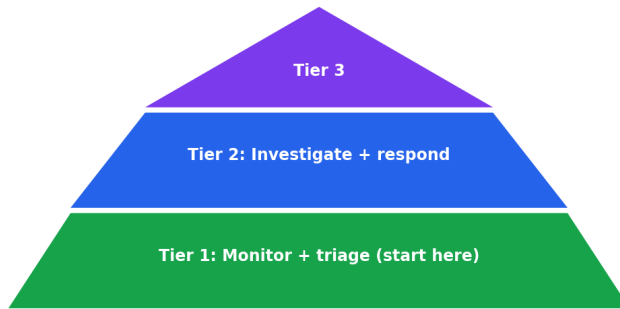


Figure 2.2: SOC tiers

Role	Main responsibilities
Tier 1 Analyst (Triage)	Monitor alerts, check if they are real, collect basic evidence, close false positives, escalate real incidents
Tier 2 Analyst (Incident responder)	Deep investigation, scoping the incident, containment actions, guiding recovery
Tier 3 / Threat hunter	Proactive hunting for hidden threats, malware analysis, improving detections
Detection engineer	Writes and tunes detection rules in the SIEM and EDR
Threat intelligence analyst	Tracks attacker groups and indicators, feeds intelligence to the SOC
SOC manager	Runs the team, reports to leadership, owns metrics and staffing

2.4 Tools You Will Meet

Tool type	Purpose	Examples
SIEM	Collect and correlate logs, raise alerts	Splunk, Microsoft Sentinel, IBM QRadar, Elastic, Wazuh
EDR / XDR	Monitor and respond on endpoints	CrowdStrike, Microsoft Defender, SentinelOne
Firewall / IDS / IPS	Filter and inspect network traffic	Palo Alto, Fortinet, Snort, Suricata
Email security	Filter phishing and malware in mail	Proofpoint, Microsoft Defender for Office 365
SOAR	Automate repetitive response steps	Splunk SOAR, Cortex XSOAR
Ticketing	Track and document incidents	ServiceNow, Jira, TheHive
Threat intel	Check reputation of IPs, domains, files	VirusTotal, AbuseIPDB, OTX

2.5 Shifts and Metrics

Many SOC's run 24x7, so analysts often work rotating shifts and write **handover notes** so the next shift knows what is open. Managers measure performance with metrics such as **MTTD** (mean time to detect), **MTTR** (mean time to respond) and the false positive rate.

2.6 A Day in the Life of a Tier 1 Analyst

Time	Activity
Start of shift	Read handover notes, check open tickets and dashboards
Morning	Triage new alerts: phishing reports, failed logins, malware detections
Midday	Investigate: check IP reputation, search logs, review the user's recent activity
Afternoon	Escalate real incidents to Tier 2, tune noisy alerts with seniors, update tickets
End of shift	Write handover notes and close or transfer cases

2.7 Skills That Matter

- **Technical:** networking, Linux and Windows basics, logs, SIEM queries, malware and phishing basics.
- **Thinking:** curiosity, attention to detail, structured problem solving.
- **Communication:** clear, short, accurate ticket notes and escalations. This is a bigger part of the job than most beginners expect.

KEY TAKEAWAYS

- A SOC is people, process and technology working together to detect and respond to attacks.
- Tier 1 is the entry level: triage, evidence, escalate.
- Good documentation and communication are as important as technical skill.

CHECK YOURSELF

- Draw the path of one log from a Windows PC to a SOC analyst.
- What is the difference between a Tier 1 and Tier 2 analyst?
- Why is a handover note important?

WATCH AND LEARN

[SOC explained](#) | [SOC analyst day in the life](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 2 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which is the entry-level SOC role?
 - A) Tier 3 hunter
 - B) SOC manager
 - C) Tier 1 analyst
 - D) Detection engineer
2. What does a SIEM do?
 - A) Collects and correlates logs and raises alerts
 - B) Replaces the firewall
 - C) Trains employees
 - D) Encrypts hard disks
3. MTTR in SOC metrics stands for:
 - A) Minimum Time To Report
 - B) Mean Time To Respond
 - C) Managed Traffic Rule
 - D) Maximum Threat Risk
4. Why are handover notes important?
 - A) They replace tickets
 - B) The next shift knows what is open and urgent
 - C) They are required by antivirus
 - D) They reduce log size
5. Which tool type automates repetitive response steps?
 - A) WAF
 - B) VPN
 - C) SOAR
 - D) DHCP

PART II

Technical Foundations

Networking, operating systems and security basics. Everything a SOC analyst investigates is built on these.

3. Networking Essentials

Attacks travel over networks, and most evidence of an attack is a network event. If you understand how normal traffic looks, abnormal traffic stands out. This chapter covers the networking you need for SOC work.

3.1 IP Addresses, MAC Addresses and NAT

- **IP address:** the logical address of a device on a network (IPv4 example: 192.168.1.10).
- **MAC address:** the hardware address of a network card, used inside a local network.
- **Private ranges:** 10.0.0.0/8, 172.16.0.0/12 and 192.168.0.0/16 are used inside organizations and are not routable on the internet [6].
- **NAT:** lets many private devices share one public IP. In logs, a public IP may represent a whole office.

3.2 The OSI and TCP/IP Models

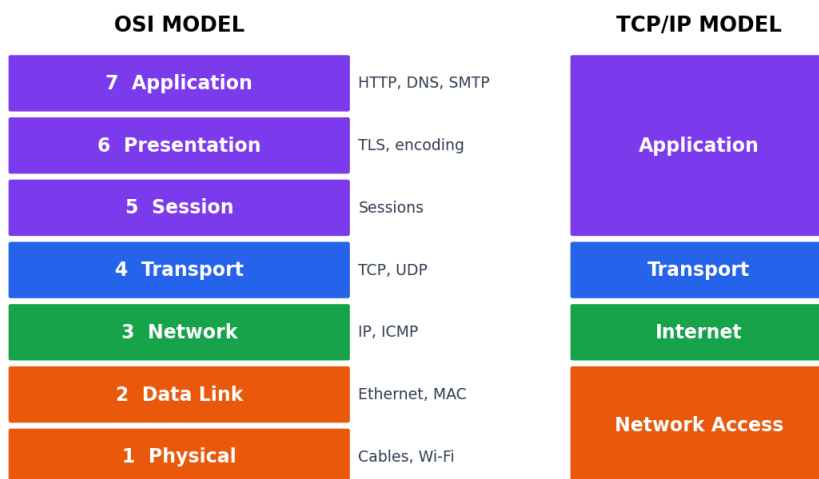


Figure 3.1: OSI and TCP/IP layers

Layers help you think about where a problem or attack happens. A phishing link is an application-layer issue, a port scan is a transport-layer issue, and ARP spoofing happens at the data link layer.

3.3 TCP, UDP and the Three-Way Handshake

TCP is reliable and connection-oriented (web, email, file transfer). **UDP** is faster and connectionless (DNS, streaming, voice). TCP starts every connection with a three-way handshake [8]:

Client	Server
---- SYN ----->	"I want to connect"
<--- SYN, ACK -----	"OK, I am ready"
---- ACK ----->	"Connection established"

Many SYN packets with no completed handshakes often indicate a port scan or a SYN flood.

3.4 DNS, DHCP and HTTP

- **DNS** translates names (example.com) into IP addresses. Attackers abuse DNS for command and control and data theft, so DNS logs are very valuable.
- **DHCP** automatically gives devices IP addresses. It lets you map an IP to a device at a specific time.
- **HTTP/HTTPS** is the web protocol. HTTPS adds TLS encryption.

DNS record	Purpose
A / AAAA	Name to IPv4 / IPv6 address
CNAME	Alias to another name
MX	Mail servers for a domain
TXT	Free text, used for SPF, DKIM and DMARC email security
NS	Authoritative name servers
PTR	IP address back to name (reverse lookup)

HTTP status	Meaning
200	OK, request succeeded
301 / 302	Redirect
401 / 403	Unauthorized / forbidden
404	Not found (many 404s from one IP can mean scanning)
500	Server error

3.5 Common Ports to Memorize

Port	Service	Security note
20/21	FTP	Unencrypted file transfer
22	SSH	Remote login, common brute force target
23	Telnet	Unencrypted, should not be used
25	SMTP	Email sending
53	DNS	Name resolution, abused for tunneling
80	HTTP	Unencrypted web
110 / 143	POP3 / IMAP	Email retrieval
123	NTP	Time sync
389	LDAP	Directory services
443	HTTPS	Encrypted web, also used to hide malicious traffic
445	SMB	Windows file sharing, used in ransomware spread
1433 / 3306	MSSQL / MySQL	Databases, should not be exposed to the internet
3389	RDP	Windows remote desktop, top ransomware entry point

3.6 Network Devices

Device	Role
Router	Connects networks and forwards traffic
Switch	Connects devices inside a LAN
Firewall	Allows or blocks traffic using rules
IDS / IPS	Detects (IDS) or blocks (IPS) suspicious traffic
Proxy	Intermediary for web traffic, adds filtering and logging
VPN	Encrypted tunnel for remote access

KEY TAKEAWAYS

- Know the models, TCP vs UDP, the handshake, DNS and the common ports.
- Normal traffic knowledge is what lets you spot abnormal traffic.
- Logs from DNS, proxy and firewall are central to investigations.

TRY IT YOURSELF

- Run `ipconfig` (Windows) or `ip a` (Linux) and identify your IP, mask and gateway.
- Run `nslookup example.com` and note the A record.
- Complete TryHackMe's Pre Security networking rooms.

WATCH AND LEARN

[Networking basics](#) | [OSI model](#) | [DNS explained](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 3 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which is a private IPv4 range?
 - A) 192.168.0.0/16
 - B) 8.8.8.0/24
 - C) 11.0.0.0/8
 - D) 1.1.1.0/24
2. What is the third step of the TCP handshake?
 - A) ACK
 - B) FIN
 - C) SYN-ACK
 - D) SYN
3. Which port does Remote Desktop (RDP) use?
 - A) 3389
 - B) 22
 - C) 53
 - D) 445
4. Which DNS record lists a domain's mail servers?
 - A) CNAME
 - B) PTR
 - C) MX
 - D) NS
5. One source sending SYN packets to many ports suggests:
 - A) DHCP activity
 - B) A software update
 - C) Normal browsing
 - D) A port scan

4. Operating Systems: Linux and Windows

Servers and workstations run Linux and Windows, and their logs are what you investigate. You do not need to be an administrator, but you must be comfortable moving around both.

4.1 Linux Essentials

Linux organizes everything in one directory tree starting at **/**. Key locations:

Path	Contains
/etc	Configuration files
/var/log	Log files
/home	User home folders
/tmp	Temporary files (attackers often drop files here)
/bin, /usr/bin	Programs

Command	What it does
ls, cd, pwd	List, change and show directory
cat, head, tail -f	Read files, follow a log live
grep	Search text, the analyst's best friend
find	Locate files
ps, top	Show running processes
ss -tulpn / netstat	Show listening ports and connections
chmod, chown	Change permissions and ownership
sudo	Run as administrator
journalctl	Read system logs on systemd systems
sort, uniq -c, awk, cut	Count and slice text output

Key logs: **/var/log/auth.log** (Debian/Ubuntu) or **/var/log/secure** (RHEL/CentOS) hold login activity; **/var/log/syslog** holds general messages. Example: list the IPs with the most failed SSH logins:

```
grep "Failed password" /var/log/auth.log \  
| awk '{print $(NF-3)}' | sort | uniq -c | sort -nr | head
```

4.2 Windows Essentials

- **Registry:** database of settings. Malware uses it to persist across reboots.
- **Services and scheduled tasks:** programs that start automatically, a favorite persistence method.
- **Processes:** know normal ones (svchost.exe, explorer.exe, lsass.exe) so you notice strange parents, like Word launching PowerShell.
- **Event Viewer:** the built-in log viewer (Security, System, Application logs).

4.3 Windows Event IDs Every Analyst Knows

Event ID	Meaning
4624	Successful logon
4625	Failed logon
4634	Logoff
4648	Logon using explicit credentials
4672	Special privileges assigned (admin logon)
4688	New process created
4720	User account created
4732	Member added to a security-enabled local group
4740	Account locked out
7045	New service installed
1102	Audit log cleared (very suspicious)
4104	PowerShell script block logged

Sysmon (a free Microsoft tool) adds richer logs: Event ID 1 (process creation), 3 (network connection) and 11 (file created). Most SOCs and labs install it [11].

4.4 Useful PowerShell

```
Get-Process # running processes  
Get-Service | Where Status -eq Running  
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625} -MaxEvents 20  
Get-ScheduledTask | Where State -ne Disabled
```

4.5 Common Persistence Places

Attackers want to survive a reboot. Remember these locations: Run and RunOnce registry keys, the Startup folder, scheduled tasks, new services, and (on Linux) cron jobs, systemd services and shell profile files. In MITRE ATT&CK these map to technique T1547 (autostart) and T1053 (scheduled task).

KEY TAKEAWAYS

- Learn grep and basic Linux navigation, you will use them constantly.
- Memorize Windows Event IDs 4624, 4625, 4688, 4720, 7045 and 1102.
- Know where persistence hides: registry Run keys, tasks, services, cron.

TRY IT YOURSELF

- On Linux, run the grep command above on your own VM after a few wrong SSH password attempts.
- On Windows, open Event Viewer, find Event 4625 after a wrong password at the lock screen.
- Install Sysmon in a VM and look at Event ID 1.

WATCH AND LEARN

[Linux for beginners](#) | [Windows Event Logs](#) | [PowerShell basics](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 4 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which Windows Event ID means a failed login?
 - A) 4624
 - B) 4688
 - C) 4625
 - D) 1102
2. Which Linux file holds SSH login attempts on Debian/Ubuntu?
 - A) /tmp/ssh.txt
 - B) /var/log/auth.log
 - C) /bin/login
 - D) /etc/hosts

3. Event ID 1102 indicates:

- A) The audit log was cleared
- B) A process started
- C) A user account was created
- D) A service was installed

4. Sysmon Event ID 3 records:

- A) Process creation
- B) A registry change
- C) File creation
- D) A network connection

5. Which is a common persistence location on Windows?

- A) The Calculator app
- B) Windows Update history
- C) Task Manager
- D) Registry Run keys

5. Security Fundamentals

5.1 Core Principles

- **Authentication:** proving who you are (password, MFA, biometrics).
- **Authorization:** what you are allowed to do after you log in.
- **Accounting:** keeping records of who did what (logs).
- **Least privilege:** give users only the access they need.
- **Defense in depth:** multiple layers so one failure does not mean total compromise.
- **Zero trust:** never trust automatically, always verify user and device.

5.2 Cryptography Basics

Concept	Explanation	Example
Symmetric encryption	One shared key encrypts and decrypts. Fast.	AES
Asymmetric encryption	Public key encrypts, private key decrypts. Solves key sharing.	RSA, ECC
Hashing	One-way fingerprint of data. Same input gives same hash; cannot be reversed.	SHA-256 (MD5 is broken for security)
Encoding	Format change, not security. Easily reversed.	Base64, URL encoding
Digital signature	Proves who signed and that data was not changed.	Signed software, certificates
TLS	Encrypts web traffic using certificates.	HTTPS

Why hashes matter in the SOC: the SHA-256 of a file is its fingerprint. You can search that hash on VirusTotal to see whether others have flagged the same file. Remember that attackers often *encode* (Base64) PowerShell commands to hide them, which you can decode with CyberChef.

5.3 Security Controls

Control	What it does
Firewall	Allows or blocks traffic by rules (IP, port, application)
IDS / IPS	Detects (and blocks) known attack patterns or anomalies
Antivirus	Detects known malware using signatures and behavior
EDR	Records endpoint activity and lets analysts investigate and isolate hosts

Control	What it does
WAF	Protects web applications from attacks like SQL injection
DLP	Prevents sensitive data from leaving the organization
Email gateway	Filters spam, phishing and malicious attachments
MFA	Second proof of identity, blocks most password attacks

5.4 Malware Types

Type	Description
Virus	Attaches to files and spreads when they are opened
Worm	Spreads by itself across networks
Trojan	Looks legitimate but does something malicious
Ransomware	Encrypts data and demands payment
Spyware / keylogger	Secretly records activity and keystrokes
RAT	Remote Access Trojan, gives the attacker control
Rootkit	Hides itself deep in the system
Botnet	Network of infected machines controlled remotely
Fileless malware	Runs in memory using built-in tools like PowerShell

5.5 Vulnerabilities and Patching

A **vulnerability** is a weakness. A **CVE** is a public ID for a known vulnerability (e.g. CVE-2021-44228, Log4Shell). **CVSS** scores severity from 0 to 10 [5]. An **exploit** is code that takes advantage of a vulnerability. Regular patching closes known holes, and many breaches happen because a patch was not applied.

KEY TAKEAWAYS

- Authentication, authorization and accounting are the base of access control.
- Hashing is one-way; encryption is two-way; encoding is not security.
- Layered controls (defense in depth) protect better than any single tool.
- Unpatched systems and weak credentials cause most breaches.

CHECK YOURSELF

- Explain the difference between encoding, encryption and hashing.
- Why is MFA so effective against brute force?
- What does EDR give an analyst that antivirus does not?

WATCH AND LEARN

[Cryptography basics](#) | [Security controls](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 5 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which statement about hashing is true?
 - A) It is one-way and cannot be reversed
 - B) It is the same as Base64
 - C) It needs a private key
 - D) It always hides the file name
2. Base64 is an example of:
 - A) Authentication
 - B) Encoding
 - C) Encryption
 - D) Hashing
3. The principle of least privilege means:
 - A) Passwords never expire
 - B) Everyone is an admin
 - C) Users get only the access they need
 - D) Only managers log in
4. Which control protects web apps from attacks such as SQL injection?
 - A) DHCP server
 - B) VPN
 - C) WAF
 - D) NTP
5. Malware that spreads by itself across a network is a:
 - A) Rootkit
 - B) Trojan
 - C) Keylogger
 - D) Worm

PART III

Core SOC Skills

Logs and SIEM, alert triage, phishing, threat intelligence and network analysis:
the daily work of a Tier 1 analyst.

This page intentionally left blank

6. Logs and SIEM

A **log** is a time-stamped record of an event: a login, a file access, a blocked connection. Logs are the evidence trail of everything that happens in an organization, and reading them is the core SOC skill.

6.1 Important Log Sources

Source	What it tells you
Windows Security logs	Logons, privilege use, account changes, process creation
Linux auth/syslog	SSH logins, sudo use, system messages
Firewall	Allowed and blocked connections, source and destination IP/port
Proxy / web gateway	Which sites users visited, downloads
DNS logs	Which domains were looked up (great for finding malware)
Email gateway	Senders, subjects, attachments, blocked phishing
EDR	Processes, files, network connections on endpoints
Cloud (AWS, Azure, M365)	Sign-ins, admin actions, resource changes

6.2 What a SIEM Does

A **Security Information and Event Management** system gathers logs from many sources and makes them searchable in one place. Its main jobs:

- 1 **Collect:** receive logs from agents and forwarders.
- 2 **Normalize:** convert different formats into common fields (source IP, user, action).
- 3 **Correlate:** link events, for example 50 failed logins followed by a success.
- 4 **Alert:** raise an alert when a rule matches.
- 5 **Visualize and retain:** dashboards and storage for investigations and audits.

Popular SIEMs include Splunk, Microsoft Sentinel, IBM QRadar and Elastic Security. **Wazuh** and **Security Onion** are free and open source, ideal for a home lab.

6.3 Learning Splunk Search

Splunk uses the Search Processing Language (SPL) [13]. A search starts with data selection, then pipes (|) results through commands. Field names depend on how data was onboarded, so adapt the examples to your environment.

```
# 1. Failed Windows logons grouped by source and user
index=main sourcetype=WinEventLog:Security EventCode=4625
| stats count by src_ip, Account_Name
| where count > 10
| sort - count
```

```
# 2. Success after many failures (possible brute force success)
index=main (EventCode=4625 OR EventCode=4624)
| stats count(eval(EventCode=4625)) as failed,
           count(eval(EventCode=4624)) as success by src_ip, Account_Name
| where failed > 10 AND success > 0
```

```
# 3. Failed logons over time (spot spikes)
index=main EventCode=4625 | timechart span=5m count
```

SPL command	Use
stats count by field	Count events grouped by a field
where / search	Filter results
sort - field	Sort descending
table field1 field2	Show only chosen columns
rex	Extract fields with regex
dedup field	Remove duplicates
timechart	Plot counts over time
top / rare	Most and least common values

6.4 Alert Fatigue

SIEMs can generate thousands of alerts, and most are harmless. **Alert fatigue** happens when analysts become numb to noise and miss the real one. Good SOCs tune rules, add context (is this user an admin? is this server critical?), and automate routine checks. As a junior, ask why an alert fires and suggest improvements: that is how analysts grow.

KEY TAKEAWAYS

- Logs are the evidence; a SIEM makes them searchable and correlated.
- Learn a few SPL patterns well: stats, where, sort, timechart.
- Context turns raw alerts into decisions.

TRY IT YOURSELF

- Install Splunk Free trial or Security Onion in your lab and ingest Windows logs.
- Reproduce search #1 after a few failed logins on your VM.
- Download the free Splunk Boss of the SOC (BOTS) dataset and answer questions from it.

WATCH AND LEARN

[Splunk fundamentals](#) | [SIEM explained](#) | [Wazuh setup](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 6 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. In a SIEM, normalizing logs means:
 - A) Deleting old logs
 - B) Blocking noisy hosts
 - C) Converting different formats into common fields
 - D) Encrypting logs
2. Which Splunk command counts events grouped by a field?
 - A) rex
 - B) dedup
 - C) stats
 - D) sort
3. Alert fatigue happens when:
 - A) Logs are encrypted
 - B) Analysts are overwhelmed by noisy alerts
 - C) Passwords are weak
 - D) The SIEM is offline
4. Which log source is very useful for finding malware domains?
 - A) DNS logs
 - B) BIOS logs
 - C) Battery logs
 - D) Printer logs

5. Which of these is a free, open-source SIEM option for a lab?

- A) Splunk Enterprise Security
- B) Wazuh
- C) Microsoft Sentinel
- D) IBM QRadar

LEARN. DETECT. DEFEND.
ZERO TO SOC | SURAJ WAGH

7. Alert Triage and Incident Response

Triage means quickly deciding what an alert is, how serious it is, and what happens next. A good triage is fast, evidence-based and clearly documented.

7.1 The Triage Questions

- 1 **What** happened? (Which rule fired, what activity?)
- 2 **Who** is involved? (User, device, source IP)
- 3 **When** and for how long? (Single event or ongoing?)
- 4 **Where?** (Which system, how important is it?)
- 5 **How bad?** (Impact on confidentiality, integrity, availability)
- 6 **Is it real?** (Check reputation, related logs, user behavior)

7.2 True and False Positives

	Alert fired	Alert did not fire
Real attack	True Positive (correct)	False Negative (dangerous: missed attack)
No attack	False Positive (noise)	True Negative (correct)

A false negative is the worst outcome, which is why you never close an alert only because it looks boring. Always check the evidence.

7.3 Severity Levels

Level	Example	Typical response
Critical (P1)	Ransomware spreading, domain admin compromised	Immediate escalation, incident team called
High (P2)	Confirmed malware on a server, successful brute force	Escalate to Tier 2 quickly
Medium (P3)	Phishing email clicked, no credentials entered	Investigate and contain within hours
Low (P4)	Blocked scan from internet, policy violation	Document and monitor

Exact definitions differ by company. Always follow your own SOC's severity matrix and escalation rules.

7.4 The Incident Response Lifecycle

The classic NIST incident response lifecycle (SP 800-61 Revision 2, 2012) describes four phases [2]. NIST's newer Revision 3 (April 2025) supersedes it and maps incident response onto the Cybersecurity Framework 2.0 functions [3], but the four-phase model is still widely taught and used in SOC playbooks:



Figure 7.1: The NIST incident response lifecycle (Revision 2 model)

- **Preparation:** tools, playbooks, training, contact lists.
- **Detection and analysis:** identify the incident and determine scope.
- **Containment, eradication and recovery:** stop the spread, remove the threat, restore normal operations.
- **Post-incident activity:** lessons learned and improvements.

7.5 Typical Containment Actions

Situation	Possible action
Compromised user account	Disable or reset password, revoke sessions, enforce MFA
Infected endpoint	Isolate from network using EDR, collect evidence, reimaging
Malicious IP or domain	Block at firewall, proxy or DNS, search logs for other victims
Phishing email	Delete from all mailboxes, block sender, notify users

WARNING

Never delete evidence, run unapproved commands on production systems, or contact attackers. Follow the playbook and escalate if unsure. Acting alone on a critical system can destroy evidence or cause an outage.

7.6 A Good Ticket Note

```
Summary : Possible brute force on VPN account jdoe
Time    : 2026-10-03 02:14 - 02:19 UTC
Source  : 203.0.113.45 (AbuseIPDB: 92% confidence, brute force)
Evidence: 54 failed logins (Event 4625), 1 success (4624) at 02:19
Verdict : True Positive, T1110 Brute Force
Action  : Account disabled, IP blocked, escalated to Tier 2
Next    : Check for lateral movement from the jdoe account
```

KEY TAKEAWAYS

- Triage = what, who, when, where, how bad, is it real.
- Never ignore a false-negative risk: check evidence before closing.
- Follow the playbook and the incident response lifecycle.
- Clear, short ticket notes make you valuable.

CHECK YOURSELF

- Why is a false negative worse than a false positive?
- List the four phases of NIST incident response.
- Write a ticket note for a phishing email that was blocked by the gateway.

WATCH AND LEARN

[Incident response process](#) | [Alert triage](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 7 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. An attack that no alert detected is a:
 - A) True positive
 - B) True negative
 - C) False positive
 - D) False negative
2. Isolating an infected host belongs to which NIST Rev. 2 phase?
 - A) Preparation
 - B) Containment, eradication and recovery
 - C) Post-incident activity
 - D) Detection and analysis
3. Before closing an alert you should:
 - A) Ask the user to reboot
 - B) Check the evidence
 - C) Delete the log
 - D) Wait one week
4. Which is a P1 (critical) example?
 - A) A single failed login
 - B) Ransomware spreading across servers
 - C) A policy violation
 - D) A blocked internet scan
5. If unsure about an action on a critical system, you should:
 - A) Follow the playbook and escalate
 - B) Try it quickly
 - C) Reboot the server
 - D) Delete suspicious files

8. Phishing Analysis

Phishing is the number one way attackers get in, so phishing analysis is the most common task for new SOC analysts. You will receive emails reported by users and must decide: is it malicious, who else received it, and what do we do?

8.1 Types of Phishing

Type	Description
Phishing	Mass emails pretending to be a trusted brand
Spear phishing	Targeted at a specific person or team
Whaling	Targets executives
BEC	Business Email Compromise: impersonating a boss or vendor to move money
Smishing / Vishing	Phishing by SMS / voice call

8.2 Red Flags in an Email

- Sender address does not match the claimed organization (micr0soft-support.com).
- Urgency or threats: 'account suspended in 24 hours'.
- Generic greeting or unexpected request for credentials or payment.
- Links where the visible text and real destination differ.
- Unexpected attachments, especially .html, .zip, .iso, .docm or password-protected files.
- Reply-To address different from the From address.

8.3 Reading Email Headers

Headers show the true path of an email. Read the **Received** lines from bottom to top (bottom is the origin).

Header	What to check
From	Displayed sender, easily faked
Reply-To	Where replies go; a mismatch is suspicious
Return-Path	Real bounce address
Received	Servers the mail passed through, with IPs and times

Header	What to check
Authentication-Results	SPF, DKIM and DMARC results
Message-ID	Unique ID; odd domains can reveal spoofing

Check	Meaning
SPF	Is the sending server allowed to send for this domain? [9]
DKIM	Is the message signed and unmodified?
DMARC	Policy for what to do when SPF/DKIM fail (standardized in RFC 9989, 2026) [10]

A sample header fragment (documentation IP and example domain):

```
From: "IT Support" <it-support@example-helpdesk.com>
Reply-To: reset@mail-secure-login.biz
Return-Path: <bounce@mail.example.net>
Received: from unknown (HELO mail.example.net) [203.0.113.77]
Authentication-Results: spf=fail; dkim=none; dmarc=fail
Subject: URGENT: Password expires today
```

Here SPF failed, DKIM is missing, and Reply-To differs from From: three strong indicators of phishing.

8.4 Step-by-Step Analysis Procedure

- 1 Do not click anything. Work in a safe environment or sandbox.
- 2 Check the sender, Reply-To and header authentication results.
- 3 Extract URLs and attachments. **Defang** them (hxxps://evil[.]com) before pasting in tickets.
- 4 Check URLs on VirusTotal and urlscan.io; check IPs on AbuseIPDB.
- 5 For attachments, get the SHA-256 hash and check it; detonate in a sandbox (such as ANY.RUN free tier) if policy allows.
- 6 Search email logs: who else received it? Who clicked? (proxy and DNS logs)
- 7 Decide the verdict, take action (block, delete, reset passwords) and document.

8.5 Response Checklist

If...	Then...
Nobody clicked	Delete from mailboxes, block sender/domain/URL
User clicked, no credentials entered	Above plus scan the endpoint, monitor
User entered credentials	Reset password, revoke sessions, check sign-in logs, escalate

If...	Then...
User opened an attachment	Isolate the endpoint, escalate to Tier 2

KEY TAKEAWAYS

- Phishing is the top initial access method (MITRE T1566).
- Check headers (SPF, DKIM, DMARC), URLs and attachments safely.
- Always find out who else received it and who interacted with it.
- Defang indicators before sharing them.

TRY IT YOURSELF

- Use MXToolbox's header analyzer on an email you received (with sensitive data removed).
- Decode a Base64 string using CyberChef.
- Practice with the phishing rooms on TryHackMe and the phishing labs on LetsDefend.

WATCH AND LEARN

[Phishing analysis](#) | [Email headers](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 8 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Email Received headers are best read:
 - A) Alphabetically
 - B) From bottom to top
 - C) Top to bottom only
 - D) Only the first line
2. SPF checks whether:
 - A) The email is encrypted
 - B) The attachment is clean
 - C) The user is on VPN
 - D) The sending server is authorized for the domain
3. Defanging a URL means:
 - A) Shortening the link
 - B) Deleting the email
 - C) Encrypting the link
 - D) Making it non-clickable, such as hxxps and [.]

4. A user entered credentials on a phishing page. First response?

- A) Reinstall Windows
- B) Do nothing
- C) Only delete the email
- D) Reset the password and revoke sessions

5. Which MITRE ATT&CK technique ID is phishing?

- A) T1021
- B) T1110
- C) T1566
- D) T1486

9. Threat Intelligence, MITRE ATT&CK and the Kill Chain

9.1 Indicators of Compromise (IOCs)

An **IOC** is evidence that a system may be compromised: a malicious IP, domain, URL, file hash, or file name. Threat intelligence gives you lists of known-bad IOCs. A weakness: attackers can change an IP or hash in minutes. More valuable are **TTPs** (tactics, techniques and procedures), the behaviors attackers cannot change easily.

9.2 Where to Check Reputation

Source	Use
VirusTotal	Files, hashes, URLs, domains and IPs checked by many engines
AbuseIPDB	Crowd-sourced IP reputation
AlienVault OTX	Community threat intelligence
URLhaus / MalwareBazaar (abuse.ch)	Known malicious URLs and malware samples
urlscan.io	Safe scan and screenshot of a URL
Talos Intelligence	Cisco's IP and domain reputation

TIP

A clean result does not prove something is safe. New malware and fresh phishing domains are often unknown to reputation sites. Combine reputation with behavior and context.

9.3 The Cyber Kill Chain

The Cyber Kill Chain, a trademark of Lockheed Martin, describes seven stages of an attack [4]. If you can stop the attacker at any stage, the attack fails.



Block the attacker at any stage to stop the attack

Figure 9.1: The seven stages of the Cyber Kill Chain

Stage	Example
1 Reconnaissance	Researching employees, scanning for open ports
2 Weaponization	Building a malicious document
3 Delivery	Phishing email with the attachment
4 Exploitation	User opens file, vulnerability triggers
5 Installation	Malware sets up persistence
6 Command and Control	Malware beacons to attacker server
7 Actions on Objectives	Data theft, ransomware, destruction

9.4 MITRE ATT&CK

MITRE ATT&CK is a free, global knowledge base of real attacker behavior [1]. It is organized as **tactics** (the attacker's goal, the 'why') and **techniques** (how they do it), each with an ID such as T1566. SOCs use it to describe attacks in a common language, to find gaps in detection and to guide threat hunting.

Tactic (Goal)	Example technique
Reconnaissance	T1595 Active Scanning
Initial Access	T1566 Phishing, T1190 Exploit Public-Facing Application
Execution	T1059 Command and Scripting Interpreter, T1204 User Execution
Persistence	T1547 Boot or Logon Autostart, T1053 Scheduled Task/Job
Privilege Escalation	T1068 Exploitation for Privilege Escalation
Defense Evasion	T1027 Obfuscated Files, T1070 Indicator Removal
Credential Access	T1110 Brute Force, T1003 OS Credential Dumping
Discovery	T1082 System Information Discovery
Lateral Movement	T1021 Remote Services
Collection	T1005 Data from Local System

Tactic (Goal)	Example technique
Command and Control	T1071 Application Layer Protocol
Exfiltration	T1041 Exfiltration Over C2 Channel
Impact	T1486 Data Encrypted for Impact (ransomware)
Resource Development	T1583 Acquire Infrastructure

Using ATT&CK in triage: after identifying an attack, map each step to a technique and ask, 'what usually comes next?' If you see T1566 (phishing) followed by T1059 (PowerShell), look for persistence (T1547) and credential access (T1003) next.

KEY TAKEAWAYS

- IOCs are easy for attackers to change; behaviors (TTPs) are harder.
- The Kill Chain describes the order of an attack; ATT&CK describes the detail.
- Learn the 14 tactics and 10-15 common techniques by heart for interviews.

TRY IT YOURSELF

- Open attack.mitre.org and read the page for T1566 and T1110.
- Pick a TryHackMe room and map every attacker action to an ATT&CK technique.
- Create your own one-page tactics cheat sheet.

WATCH AND LEARN

[MITRE ATT&CK](#) | [Cyber Kill Chain](#) | [Threat intelligence](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 9 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

- Which is hardest for attackers to change?
 - A file hash
 - A domain name
 - Their TTPs (behaviors)
 - An IP address
- In the Kill Chain, malware calling its controller is:
 - Weaponization
 - Delivery
 - Reconnaissance
 - Command and Control

3. In ATT&CK, a tactic represents:

- A) A log source
- B) The attacker's goal
- C) A malware family
- D) A specific tool

4. T1110 is which technique?

- A) Scheduled Task
- B) Brute Force
- C) OS Credential Dumping
- D) Phishing

5. A clean VirusTotal result means the item is:

- A) Definitely safe
- B) Definitely malicious
- C) Already blocked
- D) Not necessarily safe

10. Network Analysis with Wireshark

Wireshark is a free tool that captures and displays network packets [12]. It lets you see exactly what happened on the wire, which is invaluable when logs are not enough.

10.1 Getting Started

- 1 Install Wireshark from [wireshark.org](https://www.wireshark.org) and select your network interface.
 - 2 Start the capture, browse a website or run nslookup, then stop.
 - 3 Use the display filter bar to narrow results.
 - 4 Right-click a packet and choose **Follow TCP Stream** to read a conversation.
- Capture filters** limit what is recorded (for example port 53). **Display filters** hide packets after capture. Beginners mainly use display filters.

10.2 Essential Display Filters

Filter	Shows
ip.addr == 203.0.113.45	All traffic to or from this IP
tcp.port == 443	Traffic on TCP port 443
dns	All DNS packets
http.request.method == "POST"	HTTP POST requests (form submissions)
tcp.flags.syn==1 && tcp.flags.ack==0	Connection attempts (SYN only), useful for scans
tls.handshake	TLS handshakes
frame contains "password"	Packets that include a word
!(arp dns)	Exclude noise

10.3 Spotting Suspicious Behavior

Pattern	What it looks like	Possible meaning
Port scan	One source sends SYN packets to many ports or hosts	Reconnaissance (T1595)
Beaconing	Same host connects to one external IP at regular intervals	Malware calling its C2 server

Pattern	What it looks like	Possible meaning
DNS tunneling	Very long, random-looking subdomains, many TXT queries	Data exfiltration or C2 over DNS
Large upload	Huge outbound transfer at night	Data exfiltration
Cleartext credentials	FTP, Telnet or HTTP login visible in a stream	Poor security, credential exposure
Brute force	Many connections to port 22, 3389 or a login URL	Credential attack (T1110)

10.4 Where to Find Practice Captures

The Wireshark wiki sample captures and malware-traffic-analysis.net provide real packet captures with exercises. Never open unknown PCAPs on your main machine if they come from malware sources: use a virtual machine.

tshark is the command-line version of Wireshark, useful for quickly extracting fields from large captures.

```
tshark -r capture.pcap -Y dns -T fields -e ip.src -e dns.qry.name | sort | uniq -c | sort
```

KEY TAKEAWAYS

- Use display filters to find the signal in the noise.
- Learn the patterns: scan, beacon, tunnel, exfiltration, brute force.
- Practice on sample captures in a VM.

TRY IT YOURSELF

- Capture your own DNS and HTTP traffic and identify the TCP handshake.
- Download a sample PCAP and find all DNS queries and the top talkers.
- Use Follow TCP Stream on an HTTP session.

WATCH AND LEARN

[Wireshark tutorial](#) | [Packet analysis](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 10 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which Wireshark display filter shows DNS traffic?
 - A) capture dns
 - B) dns
 - C) show dns
 - D) ip.dns
2. Regular connections at fixed intervals to one external IP suggest:
 - A) Beaconing
 - B) A software update
 - C) A DHCP renewal
 - D) A port scan
3. Very long random-looking subdomains suggest:
 - A) Email delivery
 - B) NTP sync
 - C) DNS tunneling
 - D) Normal browsing
4. Follow TCP Stream lets you:
 - A) Decrypt all TLS
 - B) Delete packets
 - C) Read a whole conversation
 - D) Block an IP
5. Where should you open real malware PCAP practice files?
 - A) On your office PC
 - B) In a virtual machine
 - C) On a shared server
 - D) On a phone

This page intentionally left blank

PART IV

Hands-On Practice

Knowledge becomes skill only through practice. Build a lab, solve challenges and document your work.

This page intentionally left blank

11. Building Your Home Lab

A home lab is a small, isolated practice environment on your own computer. It is the single best way to learn for free, and it gives you something concrete to show in interviews.

11.1 What You Need

Item	Recommended
RAM	8 GB minimum, 16 GB comfortable
Disk space	100 GB or more free
CPU	Virtualization enabled in BIOS/UEFI (Intel VT-x or AMD-V)
Hypervisor	VirtualBox (free) or VMware Workstation Pro (free for personal use) [17]
Operating systems	Kali Linux, Windows 10/11 evaluation edition from Microsoft, Ubuntu Server
SIEM	Security Onion, Wazuh or Splunk trial

11.2 Lab Architecture

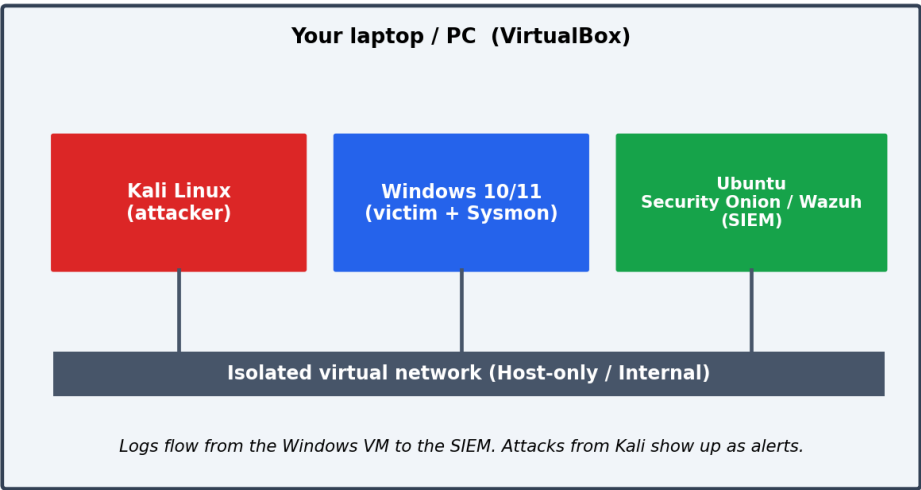


Figure 11.1: A simple home SOC lab

Keep the lab on a **host-only** or **internal** network so nothing in it can touch the internet or your home devices. Take **snapshots** before every experiment so you can roll back.

11.3 Step-by-Step Build

- 1 Enable virtualization in BIOS and install VirtualBox.
- 2 Create the Windows VM and install **Sysmon** for detailed logs.
- 3 Create the Ubuntu VM and install Wazuh or Security Onion.
- 4 Install the agent on Windows so logs flow to the SIEM.
- 5 Create the Kali VM, used only as the 'attacker' against your own lab machines.
- 6 Put all VMs on the same isolated network and take a clean snapshot.

11.4 First Experiments

- Type a wrong password several times on the Windows VM and find Event 4625 in the SIEM.
- Run a basic port scan from Kali against the Windows VM and find it in logs.
- Use **Atomic Red Team** (free) [14] to safely simulate ATT&CK techniques on your Windows VM and check whether your SIEM detects them.
- Create a custom alert: more than 10 failed logons in 5 minutes.

WARNING

Only test against machines you own, inside your isolated lab. Scanning or attacking systems without written permission is illegal and can end your career before it starts.

KEY TAKEAWAYS

- A lab proves practical skill better than any certificate.
- Isolate it, snapshot it, and document everything you do.
- The best lab exercise is detect what you generate.

WATCH AND LEARN

[Home lab setup](#) | [Wazuh lab](#) | [Atomic Red Team](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 11 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which network mode best isolates your lab?
 - A) Direct to the internet
 - B) Host-only or internal
 - C) Bridged to your home network
 - D) Public Wi-Fi
2. Why take snapshots?
 - A) To hide logs
 - B) To speed up the CPU
 - C) To roll back after experiments
 - D) To save internet data
3. Atomic Red Team is used to:
 - A) Safely simulate ATT&CK techniques
 - B) Encrypt backups
 - C) Replace the SIEM
 - D) Scan the internet
4. Recommended minimum RAM for a home lab is:
 - A) 1 GB
 - B) 512 MB
 - C) 8 GB
 - D) 2 GB
5. You should only test against:
 - A) Systems you own or have written permission for
 - B) Any website
 - C) Your neighbor's Wi-Fi
 - D) Public servers

12. Practice Platforms and CTFs

You can practice for little or no money. These platforms provide guided learning and realistic investigations, and most have a free tier.

Platform	Best for	Link
TryHackMe	Guided paths (Pre Security, SOC Level 1). The free tier is limited; the full SOC Level 1 path needs a paid plan [18]	tryhackme.com
LetsDefend	Simulated SOC with real alert queues	letsdefend.io
CyberDefenders	Blue team forensic challenges	cyberdefenders.org
Blue Team Labs Online	Defensive investigations and puzzles	blueteamlabs.online
picoCTF	Beginner friendly CTF with free practice	picoctf.org
OverTheWire (Bandit)	Learn Linux through games	overthewire.org
Splunk BOTS	Free realistic attack datasets for Splunk	github.com/splunk/botsv3
Malware-Traffic-Analysis	PCAP exercises with answers	malware-traffic-analysis.net

TIP

Cost note (checked 2026): TryHackMe has a limited free tier, and the complete SOC Level 1 path needs a paid plan (roughly US\$14 per month at the time of checking; verify on the site). If your budget is zero, start with the platforms in this table that are free: Blue Team Labs Online, picoCTF, OverTheWire, Splunk BOTS and Malware-Traffic-Analysis. Prices and free tiers change, so confirm before you commit.

12.1 How to Practice Well

- **Try first, then look:** struggle for at least 20 minutes before reading hints.
- **Take notes** in your own words, they become your write-ups.
- **Repeat:** redo a lab a week later without notes.
- **Mix learning and doing:** one hour theory, one hour lab.
- **Join a community:** Discord servers, Reddit, local meetups, and TryHackMe leaderboards.

12.2 What Are CTFs?

Capture The Flag competitions give you puzzles whose answer is a hidden 'flag'. Blue-team style CTFs (log analysis, forensics, packet analysis) are best for SOC aspirants. Play with a team if possible, and always write a short post-mortem on what you learned.

KEY TAKEAWAYS

- Free and low-cost platforms are enough to reach job-ready level.
- Consistency beats intensity: 2 hours daily beats 14 hours on Sunday.
- Every lab becomes a write-up, every write-up becomes proof.

WATCH AND LEARN

[TryHackMe walkthrough](#) | [CTF for beginners](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 12 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which platform teaches Linux through game levels?
 - A) Splunk BOTS
 - B) VirusTotal
 - C) OverTheWire (Bandit)
 - D) Wireshark
2. Splunk BOTS provides:
 - A) Free hardware
 - B) Job offers
 - C) Realistic attack datasets to investigate
 - D) Certificates only
3. Best approach when stuck on a lab:
 - A) Try for about 20 minutes before reading hints
 - B) Copy a stranger's answers
 - C) Read the solution immediately
 - D) Skip the topic
4. Which CTF style suits SOC aspirants most?
 - A) Only hardware hacking
 - B) Blue-team (logs, forensics, packets)
 - C) Only cryptography
 - D) Only web exploitation

5. Which habit works best?

- A) Only watching videos
- B) Two hours daily, consistently
- C) Fourteen hours once a week
- D) Practicing only before interviews

13. Writing Investigation Reports

Employers hire people who think clearly and communicate clearly. Publishing short investigation write-ups proves both. Use this simple format for every case:



Write every investigation in this format

Figure 13.1: Alert, Triage, Investigate, Verdict, Action, Lesson

13.1 Sample 1: Brute Force Attack

Step	Details
Alert	Multiple failed logons followed by one success from the same IP
Triage	Source 203.0.113.45, user <i>admin</i> , 47 failures in 2 minutes
Investigate	IP flagged on AbuseIPDB and VirusTotal. In Splunk, attempt 48 succeeded. No further activity seen yet.
Verdict	True Positive: brute force (T1110), valid account used (T1078)
Action	Disable account, reset password, block IP, escalate to Tier 2 to check lateral movement
Lesson	MFA and account lockout policy would have stopped it

13.2 Sample 2: Phishing Email

Step	Details
Alert	User reports 'Invoice overdue' email with a link
Triage	Sender billing@examp1e-invoices.com, SPF fail, Reply-To differs
Investigate	URL hxxps://invoice-check[.]example[.]net/login flagged by urlscan.io as credential harvesting page. 4 users received it, 1 clicked, proxy shows POST request.
Verdict	True Positive: credential phishing (T1566), possible credential compromise
Action	Delete email from all mailboxes, block domain, reset clicked user's password, revoke sessions, review sign-in logs

Step	Details
Lesson	User awareness training and external email banners reduce clicks

13.3 Sample 3: Suspicious PowerShell

Step	Details
Alert	EDR: PowerShell launched by WINWORD.EXE with an encoded command
Triage	Host FIN-PC-07, user a.khan, Event 4688 and Sysmon Event 1
Investigate	Decoded Base64 command (CyberChef): downloads a file from an unknown IP. Proxy shows repeated connections every 60 seconds (beaconing).
Verdict	True Positive: malicious macro (T1204, T1059), C2 beaconing (T1071)
Action	Isolate host with EDR, block IP, collect evidence, escalate to Tier 2, hunt for same indicators elsewhere
Lesson	Block Office macros from the internet and restrict Office child processes

13.4 Publishing Tips

- Use GitHub (a README per case) or Medium. Add screenshots with sensitive data blurred.
- Never publish real company data, customer information or internal details.
- Respect platform rules: some platforms do not allow public solutions to active challenges. Write about *your method* and learning instead.
- Aim for 5 to 8 quality write-ups rather than 30 rushed ones.
- Link them all in your resume and LinkedIn Featured section.

KEY TAKEAWAYS

- A write-up shows how you think, which is what interviewers want.
- Always follow: Alert, Triage, Investigate, Verdict, Action, Lesson.
- Protect confidentiality and platform rules.

WATCH AND LEARN

[Incident report writing](#) | [GitHub portfolio](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 13 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which is the correct write-up order?
 - A) Verdict, Alert, Triage
 - B) Alert, Triage, Investigate, Verdict, Action, Lesson
 - C) Lesson, Alert, Action
 - D) Action, Lesson, Alert
2. Should you publish real company data in a write-up?
 - A) Only on Fridays
 - B) Only if it is exciting
 - C) Yes, with a name
 - D) No, never
3. Why publish write-ups?
 - A) They increase internet speed
 - B) They replace a degree
 - C) They show how you think and communicate
 - D) They guarantee a job
4. In the brute force sample, which technique ID was used?
 - A) T1053
 - B) T1566
 - C) T1486
 - D) T1110
5. How many write-ups are recommended?
 - A) None
 - B) 1
 - C) 50 rushed ones
 - D) About 5 to 8 quality ones

This page intentionally left blank

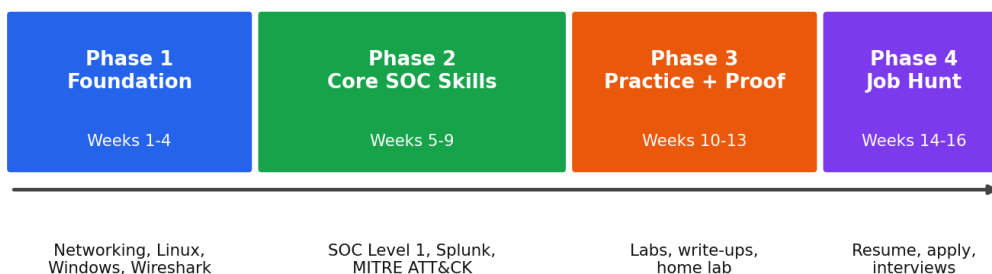
PART V

Your Career

A 16-week plan, certifications, your resume, interviews, and what happens after you get the job.

This page intentionally left blank

14. The 16-Week Study Plan



Goal: SOC Analyst Tier 1 job in about 16 weeks

Figure 14.1: The four phases

This plan assumes 2 to 3 hours per day. A simple daily rhythm: **1 hour learning** (course or video), **1 hour lab** (hands-on) and **30 minutes notes** (write what you learned). If you already know a topic, skip it and gain time for write-ups.

Week	Focus	Resources	Deliverable
1	Networking basics	TryHackMe Pre Security, Chapter 3	Notes on OSI, TCP, DNS, ports
2	Linux and Windows	TryHackMe Pre Security, Chapter 4	Cheat sheet of commands and event IDs
3	Security intro + certs	Cisco Introduction to Cybersecurity, Fortinet NSE 1	Course badge
4	Wireshark	Chapter 10, sample PCAPs	Screenshot of a TCP handshake and DNS query
5	SOC Level 1: intro, SIEM	TryHackMe SOC Level 1 part 1 (full path needs a paid plan; use free rooms and the alternatives in Chapter 12 otherwise)	Room completions
6	SOC Level 1: phishing	TryHackMe phishing rooms, Chapter 8	Header analysis notes
7	SOC Level 1: threat intel, IR	Rooms + Chapters 7 and 9	Incident response summary
8	Splunk	Splunk Fundamentals 1, Chapter 6	Certificate + 3 saved searches

Week	Focus	Resources	Deliverable
9	MITRE ATT&CK, Kill Chain	attack.mitre.org, Chapter 9	One-page tactics cheat sheet
10	Alert practice I	LetsDefend free tier	5 investigated alerts
11	Alert practice II	CyberDefenders, Blue Team Labs	5 more alerts
12	Write-ups	Chapter 13	5 published write-ups
13	Home lab	Chapter 11	Lab README with screenshots
14	Resume + LinkedIn	Chapter 16	Finished resume, profile
15	Interview prep	Chapter 16 questions	Mock interview with a friend
16	Apply daily	Chapter 17	Application tracker, 50+ applications

14.1 Staying Consistent

- Pick a fixed daily time and protect it.
- Track your streak (TryHackMe has one built in).
- Do not compare your week 3 with someone else's year 3.
- Tired? Do a 20-minute minimum session instead of skipping.
- Find a study partner for accountability.

TIP

If you are a final-year student or a working IT person, stretch the plan to 24 weeks with 1 to 1.5 hours per day. Finishing slowly is better than quitting.

WATCH AND LEARN

[Cyber security roadmap](#) | [Study tips](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 14 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. How many weeks does the study plan cover?
 - A) 8
 - B) 4
 - C) 52
 - D) 16
2. The suggested daily rhythm is:
 - A) Only notes
 - B) 30 min once a week
 - C) 8 hrs videos only
 - D) 1 hr learning, 1 hr lab, 30 min notes
3. The week 12 deliverable is:
 - A) 5 published write-ups
 - B) A new laptop
 - C) A job offer
 - D) A degree
4. If you are busy, what does the book suggest?
 - A) Stretch the plan to about 24 weeks
 - B) Quit
 - C) Study only on exam day
 - D) Skip all labs
5. Phase 4 focuses on:
 - A) Hardware repair
 - B) Game design
 - C) The job hunt
 - D) Cooking

15. Certifications

Certifications help with screening, but they are secondary to skills. Start with free ones, then let your employer sponsor the expensive ones. Fees and free offers change often, so check each official site before you start.

Certification	Cost	Why take it
ISC2 Certified in Cybersecurity (CC)	Paid (the free program closed on 20 May 2026)	Recognized entry credential. Check ISC2 for the current fee [16]
Fortinet NSE 1 to 3	Free	Quick security awareness certificates
Cisco Networking Academy badges	Free courses	Networking and cyber security fundamentals
Splunk Fundamentals 1	Free course	Shows SIEM skills
Google Cybersecurity Certificate	Paid, financial aid available	Structured beginner course, includes SIEM and Python intro
Microsoft SC-900	Learning free, exam paid	Security fundamentals for Microsoft environments
CompTIA Security+	Paid	The most commonly requested baseline certificate
CompTIA CySA+	Paid	Analyst-level detection and response
Blue Team Level 1 (BTL1)	Paid	Practical, hands-on SOC exam
Microsoft SC-200	Paid	Microsoft Sentinel and Defender analyst skills
GIAC (GCIH, GCIA)	Expensive	Highly respected, usually employer funded
CEH	Paid	Offensive awareness, appears in many job postings

15.1 Recommended Order

- 1 Free: Fortinet NSE 1 to 3, Splunk Fundamentals 1, Cisco courses and Microsoft Learn security paths.
- 2 Get your first SOC job.
- 3 Ask the company to sponsor Security+ or CySA+.
- 4 Add BTL1 or SC-200 depending on the tools your company uses.

- 5 Later: GIAC or specialized certifications.

15.2 Mistakes to Avoid

- Paying for expensive exam bundles before you have any practical experience.
- Collecting many entry certificates with no projects.
- Memorizing exam dumps. Interviewers can tell instantly.

KEY TAKEAWAYS

- Skills plus proof beat certificates alone.
- Use free certificates to get started.
- Employer sponsorship is the smartest way to fund expensive exams.

WATCH AND LEARN

[Which certification first](#) | [ISC2 CC](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 15 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. What is the status of ISC2's free CC program?
 - A) It became lifetime free
 - B) It never existed
 - C) It is unlimited
 - D) It closed to new enrollments on 20 May 2026
2. Fortinet NSE 1 to 3 courses are:
 - A) Free
 - B) Invitation only
 - C) Very expensive
 - D) Only for managers
3. Which paid certificate is most often requested as a baseline?
 - A) None
 - B) CompTIA Security+
 - C) Any random badge
 - D) A cooking certificate
4. The smartest way to fund expensive certificates is:
 - A) Borrowing without a plan
 - B) Buying exam dumps
 - C) Skipping labs
 - D) Employer sponsorship

5. Which certificate is a practical, hands-on blue team exam?

- A) Blue Team Level 1 (BTL1)
- B) CEH only
- C) A typing test
- D) A driving test

LEARN. DETECT. DEFEND.
ZERO TO SOC | SURAJ WAGH

16. Resume, LinkedIn and Interviews

16.1 The Resume

- One page, simple layout, no photos, no tables that confuse applicant tracking systems.
- Use keywords from the job post: SIEM, Splunk, incident response, phishing, MITRE ATT&CK, log analysis.
- Show **actions and results**, not duties. 'Investigated 25 simulated alerts in LetsDefend and documented 5 incidents' is stronger than 'Learned SOC'.

Section	Example
Summary	B.Tech IT graduate with hands-on SOC practice in SIEM, phishing analysis and incident triage.
Skills	Splunk, Wireshark, Sysmon, log analysis, MITRE ATT&CK, Linux, Windows, networking
Projects	Home SOC lab (link). 5 investigation write-ups (links). Detection rules created in Wazuh.
Certifications	Fortinet NSE 1 to 3, Cisco Introduction to Cybersecurity, Splunk Fundamentals 1
Education	B.Tech, Information Technology
Profiles	TryHackMe rank, GitHub, LinkedIn

16.2 LinkedIn

- **Headline:** 'Aspiring SOC Analyst | Splunk | Wireshark | MITRE ATT&CK | TryHackMe'.
- Add a clear photo, an About section in 4 to 5 lines and your projects in **Featured**.
- Post short learning updates weekly: a lab you finished, a tool you learned.
- Connect with SOC analysts and recruiters. Send a short note, not a request for a job (see Chapter 17).

16.3 The Interview Process

Typical rounds: HR screening, technical interview, scenario or practical test, and a manager round. Use the **STAR** method for behavioral questions: Situation, Task, Action, Result.

16.4 Questions and Strong Answers

Question	Strong answer outline
Explain the CIA triad.	Confidentiality, integrity, availability, with one example each.
TCP vs UDP?	TCP: reliable, connection-oriented, handshake. UDP: fast, connectionless. Examples for each.
How does DNS work?	Client asks a resolver, which queries root, TLD and authoritative servers and returns the IP. Mention DNS tunneling as an abuse.
What is a firewall? IDS vs IPS?	Firewall filters traffic by rules. IDS detects and alerts, IPS detects and blocks.
Encryption vs hashing vs encoding?	Encryption is reversible with a key, hashing is one-way, encoding is a reversible format change with no security.
What is MITRE ATT&CK?	Knowledge base of tactics and techniques used to describe attacks and improve detections. Give an example technique.
True vs false positive?	True positive: real threat flagged. False positive: harmless activity flagged. Mention tuning and false negatives.
How do you detect brute force?	Many failed logins from one source (4625) followed by success (4624), alert on thresholds, check IP reputation, add MFA and lockout.
What would you do if a user clicked a phishing link?	Isolate if needed, check URL reputation, check proxy and sign-in logs, reset credentials, find other recipients, block indicators, document.
What is lateral movement?	Attacker moving between systems after the first compromise, e.g. RDP or SMB (T1021). Detect via unusual logons between hosts.
What is the difference between an event, alert and incident?	Event: anything logged. Alert: event matching a rule. Incident: confirmed security event requiring response.
Tell me about a project.	Walk through one write-up: Alert, Triage, Investigate, Verdict, Action, Lesson.
Why SOC? Why us?	Genuine interest, hands-on practice, willingness to work shifts, and a reason related to the company.
Are you comfortable with shift work?	Be honest and positive: explain how you manage sleep, routine and handovers.
What is your weakness?	A real, improving one: 'I used to write long notes; now I focus on short, clear summaries'.

TIP

If you do not know an answer, say so, then explain how you would find out. SOC teams value honesty and a learning attitude over bluffing.

KEY TAKEAWAYS

- Resume: one page, keywords, results.
- LinkedIn: headline, featured projects, weekly posts.
- Answer interview questions with examples from your own write-ups.

WATCH AND LEARN

[SOC interview questions](#) | [Resume tips](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 16 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. A fresher's resume should be about:
 - A) One page
 - B) Five pages
 - C) A single line
 - D) Ten pages
2. STAR stands for:
 - A) Skill, Tool, Answer, Role
 - B) Situation, Task, Action, Result
 - C) Security, Threat, Alert, Response
 - D) Start, Think, Act, Repeat
3. What belongs in the LinkedIn Featured section?
 - A) Nothing
 - B) Your passwords
 - C) Random memes
 - D) Your projects and write-ups
4. If you do not know an interview answer, you should:
 - A) End the interview
 - B) Stay silent
 - C) Make something up
 - D) Say so and explain how you would find out

5. Which resume bullet is stronger?

- A) Learned SOC
- B) Investigated 25 lab alerts and documented 5 incidents
- C) Hard worker
- D) Good with computers

17. Job Hunt and Your First 90 Days

17.1 Job Titles to Search

- SOC Analyst Tier 1 / L1
- Security Analyst (Trainee or Junior)
- Cyber Security Intern / Associate
- Security Operations Analyst
- Incident Response Analyst (Junior)
- MDR / Managed Security Analyst (security service providers hire many freshers)

17.2 Where to Apply

- [LinkedIn Jobs](#), [Naukri](#), [Foundit](#), Indeed, and company career pages.
- Managed security providers, IT services companies and MSSPs often have the most entry roles.
- Campus placements, internships and referrals are strong routes.

17.3 Daily Job-Hunt Routine

Time	Task
30 min	Search and apply to 5 to 10 relevant jobs
20 min	Connect with 3 to 5 professionals or recruiters
60 min	Keep learning: one lab or one new write-up
10 min	Update your application tracker (company, date, status, follow-up)

17.4 Networking Without Being Awkward

Ask for advice, not a job. Keep it short and specific:

Hi Priya, I'm an IT graduate building SOC skills (Splunk, Wireshark, LetsDefend). I read your post on phishing triage and found it useful. Could I ask one question about starting in a SOC? Thank you for your time.

17.5 Handling Rejection

Rejection is normal, even for strong candidates. After each interview, write down the questions you could not answer and study them. Ten interviews with feedback teach more than a hundred unread applications.

17.6 Your First 30, 60 and 90 Days

Period	Goals
Days 1-30	Learn the tools, playbooks and ticketing flow. Shadow seniors. Handle low-risk alerts. Ask many questions and take notes.
Days 31-60	Triage alerts independently. Escalate with clear, complete notes. Learn the environment's normal behavior.
Days 61-90	Suggest one tuning improvement. Start learning toward Tier 2: deeper investigations, one new tool or certification.

17.7 Shift Work and Wellbeing

Many SOC's run 24x7. Protect your sleep, keep a routine, use handover notes and talk to your manager if you feel overloaded. Burnout is real in security, and taking care of yourself is part of being a good analyst.

KEY TAKEAWAYS

- Apply daily, network politely, and learn from each rejection.
- MSSPs and IT services firms hire the most freshers.
- In your first 90 days: learn, be reliable, document well.

WATCH AND LEARN

[Getting first SOC job](#) | [First 90 days](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 17 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which employers often hire many freshers for SOC roles?
 - A) MSSPs and IT services firms
 - B) Only banks' boards
 - C) Only government ministers
 - D) Nobody
2. A networking message should:
 - A) Be 2000 words long
 - B) Attach your passwords
 - C) Ask for advice, not a job
 - D) Demand a referral
3. What is the focus of your first 30 days?
 - A) Work alone
 - B) Rewrite all rules
 - C) Learn tools and playbooks, shadow seniors
 - D) Skip handovers
4. After an interview rejection you should:
 - A) Delete your profile
 - B) Stop applying
 - C) Note unanswered questions and study them
 - D) Blame the recruiter
5. Good shift-work wellbeing includes:
 - A) Protecting sleep and keeping a routine
 - B) Skipping meals
 - C) Never taking breaks
 - D) Working all weekends

18. Career Paths and Professional Ethics

18.1 Where SOC Can Lead

Path	What you do	What to learn next
Tier 2 / Incident responder	Lead investigations and containment	Memory forensics, EDR deep dives, scripting
Threat hunter	Proactively search for hidden attackers	ATT&CK, hypothesis-driven hunting, advanced SIEM
DFIR	Forensics of disks, memory and logs	Autopsy, Volatility, timeline analysis
Detection engineer	Write and test detection rules	Sigma rules, Python, regex, ATT&CK coverage
Threat intelligence	Research attackers and campaigns	Reporting, OSINT, malware families
Penetration tester / red team	Ethically simulate attacks	Web security, Active Directory, exploitation, OSCP
Cloud security	Secure AWS, Azure and GCP	Cloud fundamentals, IAM, cloud logging
Security engineer / architect	Design and build defenses	Networking depth, automation, architecture
GRC	Policies, risk and compliance	ISO 27001, NIST CSF, audit skills

18.2 Learning Python

A little Python goes a long way: parse logs, call threat intelligence APIs, and automate boring tasks. Start with simple scripts that read a log file and count failed logins. You do not need to be a developer.

18.3 Ethics and the Law

- **Authorization first:** only test or investigate systems you are explicitly allowed to.
- **Privacy:** SOC analysts see sensitive data. Never share or browse it without need.
- **Confidentiality:** do not discuss customer or incident details publicly.

- **Responsible disclosure:** if you find a vulnerability, report it to the owner and do not exploit or publish it.
- **Laws:** unauthorized access is a crime in most countries. In India, for example, the Information Technology Act, 2000 covers it [15], and other countries have similar laws.
- **Integrity:** report honestly, including your own mistakes.

18.4 Never Stop Learning

- Follow security news: The Hacker News, BleepingComputer, Krebs on Security.
- Read incident reports and the DFIR Report to see real attacks step by step.
- Join local meetups and communities such as OWASP and Null chapters.
- Teach what you learn: writing and answering questions makes you stronger.

KEY TAKEAWAYS

- SOC is a launchpad into many specializations.
- Python and automation multiply your value.
- Ethics and legality are not optional, they define the profession.

WATCH AND LEARN

[Cyber security careers](#) | [Python for security](#)

(These open YouTube searches so you always get current videos.)

CHAPTER 18 QUIZ

Test yourself, then check the Quiz Answer Key on page 93.

1. Which role writes and tunes detection rules?
 - A) Detection engineer
 - B) Help desk
 - C) SOC manager only
 - D) Auditor only
2. Which Indian law covers unauthorized access to computers?
 - A) Motor Vehicles Act
 - B) Companies Act
 - C) Consumer Protection Act
 - D) Information Technology Act, 2000

3. If you find a vulnerability, you should:

- A) Exploit it
- B) Post it publicly first
- C) Report it to the owner responsibly
- D) Sell it

4. Python helps SOC analysts to:

- A) Replace all tools
- B) Avoid learning networking
- C) Parse logs and automate tasks
- D) Skip investigations

5. Which role ethically simulates attacks?

- A) Tier 1 analyst
- B) Penetration tester / red team
- C) GRC auditor
- D) Help desk

Appendix A: Cheat Sheets

A.1 Windows Security Event IDs

ID	Meaning	ID	Meaning
4624	Logon success	4720	Account created
4625	Logon failure	4722	Account enabled
4634	Logoff	4724	Password reset attempt
4648	Explicit credentials	4726	Account deleted
4672	Special privileges	4732	Added to local group
4688	Process created	4740	Account locked out
4697 / 7045	Service installed	1102	Audit log cleared
4698	Scheduled task created	4104	PowerShell script block

A.2 Sysmon Event IDs

ID	Meaning
1	Process creation
3	Network connection
7	Image (DLL) loaded
8	CreateRemoteThread
10	Process access (e.g., LSASS)
11	File created
13	Registry value set
22	DNS query

A.3 Linux Quick Reference

```
whoami; id; hostname          # who and where am I
ps aux | grep suspicious      # find a process
ss -tulpn                     # listening ports
last; lastb                   # successful and failed logins
grep -i "failed" /var/log/auth.log | tail
find / -mtime -1 -type f 2>/dev/null | head # files changed in 24h
crontab -l; ls /etc/cron*      # scheduled jobs
sha256sum file.bin             # file hash for reputation checks
```

A.4 Defanging and Hashing

```
http://evil.com/login -> hxxp://evil[.]com/login
185.1.2.3              -> 185[.]1[.]2[.]3
Get-FileHash .\file.exe -Algorithm SHA256      (PowerShell)
```

Appendix B: Resource Directory

Links were correct at the time of writing. Websites and free offers change, so search by name if a link has moved.

Learning platforms

- [TryHackMe](https://tryhackme.com) tryhackme.com
- [Cisco Skills for All](https://www.skillsforall.com) www.skillsforall.com
- [Fortinet Training](https://training.fortinet.com) training.fortinet.com
- [Splunk Training](https://www.splunk.com/en_us/training.html) www.splunk.com/en_us/training.html
- [Google Cybersecurity Certificate](https://www.coursera.org/professional-certificates/google-cybersecurity) www.coursera.org/professional-certificates/google-cybersecurity
- [ISC2 CC \(paid; free program ended May 2026\)](https://www.isc2.org/certifications/cc) www.isc2.org/certifications/cc
- [HTB Academy](https://academy.hackthebox.com) academy.hackthebox.com

Practice and challenges

- [LetsDefend](https://letsdefend.io) letsdefend.io
- [CyberDefenders](https://cyberdefenders.org) cyberdefenders.org
- [Blue Team Labs Online](https://blueteamlabs.online) blueteamlabs.online
- [picoCTF](https://picoctf.org) picoctf.org
- [OverTheWire](https://overthewire.org) overthewire.org
- [Splunk BOTS v3](https://github.com/splunk/botsv3) github.com/splunk/botsv3
- [Malware-Traffic-Analysis](https://www.malware-traffic-analysis.net) www.malware-traffic-analysis.net

Threat intelligence and analysis tools

- [VirusTotal](https://www.virustotal.com) www.virustotal.com
- [AbuseIPDB](https://www.abuseipdb.com) www.abuseipdb.com
- urlscan.io urlscan.io
- [ANY.RUN](https://any.run) any.run
- [AlienVault OTX](https://otx.alienvault.com) otx.alienvault.com
- [URLhaus](https://urlhaus.abuse.ch) urlhaus.abuse.ch
- [MalwareBazaar](https://bazaar.abuse.ch) bazaar.abuse.ch
- [MXToolbox](https://mxtoolbox.com) mxtoolbox.com
- [CyberChef](https://gchq.github.io/CyberChef/) gchq.github.io/CyberChef/

Frameworks and standards

- [MITRE ATT&CK](https://attack.mitre.org) attack.mitre.org
- [NIST SP 800-61 \(Incident Handling\)](https://csrc.nist.gov/pubs/sp/800/61/r2/final) csrc.nist.gov/pubs/sp/800/61/r2/final
- [OWASP](https://owasp.org) owasp.org
- [CISA](https://www.cisa.gov) www.cisa.gov

Lab software

- [VirtualBox](https://www.virtualbox.org) www.virtualbox.org
- [Kali Linux](https://www.kali.org) www.kali.org
- [Wireshark](https://www.wireshark.org) www.wireshark.org
- [Security Onion](https://securityonionsolutions.com) securityonionsolutions.com
- [Wazuh](https://wazuh.com) wazuh.com
- [Sysmon](https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon) learn.microsoft.com/en-us/sysinternals/downloads/sysmon
- [Atomic Red Team](https://github.com/redcanaryco/atomic-red-team) github.com/redcanaryco/atomic-red-team

YouTube channels to search by name

NetworkChuck, John Hammond, David Bombal, Professor Messer, The Cyber Mentor, Simply Cyber (Gerald Auger), 13Cubed, IppSec, Practical Networking. Search each name on YouTube for current content. Their topics range from networking to malware and DFIR.

Appendix C: Checklists

C.1 Alert Triage Checklist

- Read the alert rule and understand why it fired.
- Identify user, host, source and destination IP, and time.
- Check reputation of IPs, domains and hashes.
- Look at related logs before and after the event.
- Decide: true positive, false positive or unclear (escalate).
- Take or recommend containment actions per playbook.
- Write the ticket note and hand over clearly.

C.2 Phishing Checklist

- Do not click or open anything on a normal machine.
- Check From, Reply-To, Return-Path, SPF, DKIM, DMARC.
- Defang and check every URL and attachment hash.
- Find all recipients and anyone who clicked or opened.
- Block sender, domain and URL; remove emails.
- Reset credentials and isolate hosts if needed.

C.3 Before You Apply Checklist

- Resume is one page with links that open.
- GitHub has 5 or more clean write-ups with README files.
- TryHackMe profile is public with a visible streak.
- LinkedIn headline and Featured section are updated.
- You can explain your top 3 projects in 2 minutes each.
- You can answer the 15 interview questions in Chapter 16 out loud.

This page intentionally left blank

References and Citations

Numbers in square brackets in the text, such as [1], point to the sources below. Online sources were checked in October 2026. Facts, prices and free offers change, so confirm them on the official sites.

- [1] MITRE Corporation. *MITRE ATT&CK®*. Terms of use: attack.mitre.org/resources/legal-and-branding/terms-of-use/ attack.mitre.org
- [2] Cichonski, P., Millar, T., Grance, T., Scarfone, K. (2012). *Computer Security Incident Handling Guide*, NIST Special Publication 800-61 Revision 2 (superseded by Revision 3). National Institute of Standards and Technology. doi.org/10.6028/NIST.SP.800-61r2
- [3] Nelson, A., Rekhi, S., Souppaya, M., Scarfone, K. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*, NIST SP 800-61 Revision 3. NIST. csrc.nist.gov/pubs/sp/800/61/r3/final
- [4] Hutchins, E. M., Cloppert, M. J., Amin, R. M. (2011). Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains. *Leading Issues in Information Warfare & Security Research*. Also: Lockheed Martin, *Cyber Kill Chain*. www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html
- [5] FIRST.Org, Inc. *Common Vulnerability Scoring System (CVSS)*. www.first.org/cvss/
- [6] Rekhter, Y., Moskowitz, B., Karrenberg, D., de Groot, G. J., Lear, E. (1996). *Address Allocation for Private Internets*. IETF RFC 1918. www.rfc-editor.org/info/rfc1918
- [7] Arkko, J., Cotton, M., Vegoda, L. (2010). *IPv4 Address Blocks Reserved for Documentation*. IETF RFC 5737. (Source of the example IP ranges used in this book.) www.rfc-editor.org/info/rfc5737
- [8] Eddy, W. (Ed.) (2022). *Transmission Control Protocol (TCP)*. IETF RFC 9293. www.rfc-editor.org/info/rfc9293
- [9] Kitterman, S. (2014). *Sender Policy Framework (SPF)*. IETF RFC 7208. Crocker, D., Hansen, T., Kucherawy, M. (Eds.) (2011). *DomainKeys Identified Mail (DKIM) Signatures*. IETF RFC 6376. www.rfc-editor.org/info/rfc7208
- [10] Herr, T., Levine, J. (Eds.) (2026, May). *Domain-based Message Authentication, Reporting, and Conformance (DMARC)*. IETF RFC 9989 (obsoletes RFC 7489). www.rfc-editor.org/rfc/rfc9989
- [11] Microsoft. *Sysmon, Sysinternals documentation*. Microsoft Learn. learn.microsoft.com/en-us/sysinternals/downloads/sysmon
- [12] Wireshark Foundation. *Wireshark User's Guide*. www.wireshark.org/docs/wsug_html_chunked/
- [13] Splunk Inc. *Splunk Search Reference (SPL)*. docs.splunk.com/Documentation/Splunk/latest/SearchReference
- [14] Red Canary. *Atomic Red Team* (open-source project). github.com/redcanaryco/atomic-red-team
- [15] Government of India. *The Information Technology Act, 2000* (Act No. 21 of 2000). India Code. www.indiacode.nic.in

- [16] ISC2. *One Million Certified in Cybersecurity*: program conclusion notice (free enrollment closed 20 May 2026; issued exam codes valid to 31 December 2026). www.isc2.org/100k
- [17] Broadcom / VMware. *VMware Fusion Pro and Workstation Pro now free for personal use; Workstation Player discontinued* (May 2024). blogs.vmware.com/teamfusion/2024/05/fusion-pro-now-available-free-for-personal-use.html
- [18] TryHackMe. *Learning paths, SOC Level 1 and plans*. Pricing and free-tier limits change; verify on the site. tryhackme.com

Licences, Trademarks and Attribution

MITRE ATT&CK®. This book describes ATT&CK tactics and technique names and IDs under MITRE's ATT&CK Terms of Use, which grant a non-exclusive, royalty-free licence for research, development and commercial purposes provided MITRE's copyright designation is reproduced. The designation reads: © 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. The full licence is at attack.mitre.org/resources/legal-and-branding/terms-of-use/. MITRE and ATT&CK are trademarks of The MITRE Corporation.

Cyber Kill Chain. The name is a trademark of Lockheed Martin Corporation. The diagram in this book is original artwork that illustrates the publicly described seven stages.

NIST publications are works of the US National Institute of Standards and Technology and are cited, not reproduced. **IETF RFCs** are cited by number and title only.

Other names. TryHackMe, Cisco, Fortinet, Splunk, Microsoft, Google, Coursera, CompTIA, ISC2, VMware, Wireshark, Kali Linux, VirtualBox, Wazuh, Security Onion, LetsDefend, CyberDefenders, VirusTotal and other product and company names are trademarks of their respective owners and are used only to identify them. No logos or third-party images appear in this book. All diagrams, tables and text were created by the author for this book.

Quiz Answer Key

Check your answers chapter by chapter. If you missed a question, reread the section of the chapter it came from.

Chapter 1: Introduction to Cyber Security

1. **D** — It encrypts files so people cannot use their data.
2. **C** — Insiders misuse normal access, so their activity looks routine.
3. **A** — Unauthorized people can now read private data.
4. **B** — Blue teams monitor, detect and respond.
5. **D** — Phishing uses deceptive messages to steal credentials.

Chapter 2: What Is a Security Operations Center?

1. **C** — Tier 1 does triage and escalation.
2. **A** — A SIEM centralizes logs and detects patterns.
3. **B** — It measures how fast the team responds.
4. **B** — SOCs run around the clock, so continuity matters.
5. **C** — SOAR automates playbook actions.

Chapter 3: Networking Essentials

1. **A** — RFC 1918 reserves 10/8, 172.16/12 and 192.168/16.
2. **A** — The sequence is SYN, SYN-ACK, ACK.
3. **A** — RDP uses TCP 3389 and is a common ransomware entry point.
4. **C** — MX means Mail Exchanger.
5. **D** — Scanners probe many ports quickly.

Chapter 4: Operating Systems: Linux and Windows

1. **C** — 4624 is success and 4625 is failure.
2. **B** — auth.log records authentication events.
3. **A** — Clearing logs is highly suspicious.
4. **D** — ID 1 is process creation, 3 is network connection.
5. **D** — Run keys launch programs at logon.

Chapter 5: Security Fundamentals

1. **A** — Hashes are fingerprints, not reversible.
2. **B** — Base64 changes format; it provides no secrecy.
3. **C** — It limits damage if an account is compromised.
4. **C** — A Web Application Firewall filters malicious web requests.
5. **D** — Worms self-propagate without user action.

Chapter 6: Logs and SIEM

1. **C** — Normalization lets you search across sources.
2. **C** — stats count by field is the core pattern.
3. **B** — Too much noise hides the real alert.
4. **A** — Malware must resolve domain names.
5. **B** — Wazuh and Security Onion are free.

Chapter 7: Alert Triage and Incident Response

1. **D** — Missed attacks are the most dangerous outcome.
2. **B** — Containment stops the spread.
3. **B** — Never close an alert just because it looks boring.
4. **B** — Widespread impact means critical severity.
5. **A** — Acting alone can destroy evidence or cause outages.

Chapter 8: Phishing Analysis

1. **B** — The bottom line is the origin.
2. **D** — SPF lists allowed sending servers.
3. **D** — It prevents accidental clicks.
4. **D** — Stolen credentials must be invalidated.
5. **C** — T1110 is brute force and T1486 is ransomware impact.

Chapter 9: Threat Intelligence, MITRE ATT&CK and the Kill Chain

1. **C** — Behaviors are costlier to change than indicators.
2. **D** — C2 is stage six.
3. **B** — Techniques describe how the goal is achieved.
4. **B** — It belongs to Credential Access.
5. **D** — New threats are often unknown to reputation sites.

Chapter 10: Network Analysis with Wireshark

1. **B** — Protocol names work as display filters.
2. **A** — Malware often checks in on a timer.
3. **C** — Data can be hidden inside DNS queries.
4. **C** — It reassembles the data of one session.
5. **B** — Isolation protects your main system.

Chapter 11: Building Your Home Lab

1. **B** — Isolation keeps lab activity contained.
2. **C** — Snapshots restore a clean state.
3. **A** — It lets you test whether detections work.
4. **C** — 16 GB is more comfortable.
5. **A** — Unauthorized testing is illegal.

Chapter 12: Practice Platforms and CTFs

1. **C** — Bandit is a classic Linux wargame.
2. **C** — BOTS is a free dataset series for practice.
3. **A** — Struggling builds skill.
4. **B** — It mirrors SOC work.
5. **B** — Consistency beats intensity.

Chapter 13: Writing Investigation Reports

1. **B** — The same flow is used for every case.
2. **D** — Protect confidentiality.
3. **C** — Employers hire clear thinkers.
4. **D** — T1110 is Brute Force.
5. **D** — Quality matters more than quantity.

Chapter 14: The 16-Week Study Plan

1. **D** — It has four phases over 16 weeks.
2. **D** — Balance learning, doing and writing.
3. **A** — Proof of work comes from write-ups.
4. **A** — Slow progress beats quitting.
5. **C** — Resume, interviews and applications.

Chapter 15: Certifications

1. **D** — Check ISC2 for current fees.
2. **A** — They are self-paced and free.
3. **B** — It appears in many job posts.
4. **D** — Get a job first, then ask.
5. **A** — BTL1 tests practical SOC skills.

Chapter 16: Resume, LinkedIn and Interviews

1. **A** — Short and focused is best.
2. **B** — STAR structures behavioral answers.
3. **D** — It showcases proof of work.
4. **D** — Honesty and curiosity are valued.
5. **B** — Results beat vague duties.

Chapter 17: Job Hunt and Your First 90 Days

1. **A** — Managed security providers need many analysts.
2. **C** — Short and specific works best.
3. **C** — Learning comes first.
4. **C** — Feedback builds skill.
5. **A** — Burnout is real in security.

Chapter 18: Career Paths and Professional Ethics

1. **A** — They improve SIEM and EDR detections.
2. **D** — Other countries have similar laws.
3. **C** — Responsible disclosure protects users.
4. **C** — Even simple scripts save time.
5. **B** — Red teams test defenses with permission.

Glossary

Alert — A notification raised by a security tool when something matches a detection rule.

Antivirus — Software that detects and removes known malware using signatures and behavior.

APT — Advanced Persistent Threat: a skilled, well-funded attacker who stays hidden in a network for a long time.

Authentication — Proving who you are, for example with a password and a one-time code.

Authorization — Deciding what an authenticated user is allowed to do.

Availability — The CIA goal that systems and data are accessible when needed.

Beaconing — Regular, repeated connections from malware to its controller.

Blue team — Defenders who monitor, detect and respond to attacks.

Botnet — A network of infected machines controlled by an attacker.

Brute force — Trying many passwords until one works.

C2 (Command and Control) — Infrastructure an attacker uses to communicate with and control compromised systems.

CIA triad — Confidentiality, Integrity and Availability: the three core security goals.

Containment — Actions that stop an incident from spreading, such as isolating a host.

CTF — Capture The Flag: a security competition where you solve challenges to find hidden flags.

CVE — Common Vulnerabilities and Exposures: a public ID for a known vulnerability.

CVSS — Common Vulnerability Scoring System: a 0 to 10 severity score for vulnerabilities.

DDoS — Distributed Denial of Service: flooding a service from many sources to make it unavailable.

Defanging — Altering a URL or IP (hxxp, [..]) so it cannot be clicked accidentally.

Defense in depth — Using multiple layers of security so one failure is not fatal.

DFIR — Digital Forensics and Incident Response.

DHCP — Protocol that automatically assigns IP addresses to devices.

DKIM — Email authentication that signs messages so tampering can be detected.

DLP — Data Loss Prevention: tools that stop sensitive data leaving the organization.

DMARC — Email policy that tells receivers what to do when SPF or DKIM fail.

DNS — Domain Name System: translates domain names into IP addresses.

EDR — Endpoint Detection and Response: tools that record endpoint activity and allow investigation and isolation.

Encoding — Changing data format (such as Base64). It is not encryption.

Encryption — Scrambling data so only someone with the key can read it.

Event — Any recorded occurrence in a system, such as a login.

Exploit — Code or technique that takes advantage of a vulnerability.

False negative — A real attack that no alert detected.

False positive — An alert that fired on harmless activity.

Firewall — A device or software that allows or blocks network traffic by rules.

Hash — A fixed-length one-way fingerprint of data, such as SHA-256.

IDS / IPS — Intrusion Detection System (alerts) and Intrusion Prevention System (blocks).

Incident — A confirmed security event that needs a response.

Integrity — The CIA goal that data stays accurate and unaltered.

IOC — Indicator of Compromise: evidence like a malicious IP, domain or file hash.

Kill Chain — A seven-stage model of how cyber attacks progress, from reconnaissance to actions on objectives.

Lateral movement — An attacker moving from one compromised system to others in the network.

Least privilege — Giving users only the minimum access needed for their work.

Log — A time-stamped record of an event.

Malware — Malicious software of any kind.

MFA — Multi-Factor Authentication: using two or more proofs of identity.

MITRE ATT&CK — A knowledge base of real attacker tactics and techniques.

MSSP — Managed Security Service Provider: a company that runs security monitoring for other organizations.

MTTD / MTTR — Mean Time To Detect / Mean Time To Respond: key SOC performance metrics.

NAT — Network Address Translation: lets many private devices share one public IP.

NIST — US standards body whose frameworks, such as SP 800-61, guide incident response.

Packet — A small unit of data sent across a network.

Patch — A software update that fixes vulnerabilities or bugs.

Persistence — Techniques that let an attacker keep access after a reboot or logout.

Phishing — Fraudulent messages that trick people into revealing information or running malware.

Playbook — A documented set of steps for handling a specific type of alert or incident.

Port — A numbered endpoint that identifies a service on a device, such as 443 for HTTPS.

Port scan — Probing many ports on a host to find open services.

Ransomware — Malware that encrypts files and demands payment.

RAT — Remote Access Trojan: malware that gives an attacker remote control.

Red team — Ethical attackers who simulate real threats to test defenses.

Runbook — Detailed step-by-step operational instructions for a task.

Sandbox — An isolated environment for safely running suspicious files.

Severity — A rating of how serious an alert or incident is.

SIEM — Security Information and Event Management: collects, correlates and alerts on logs.

SOAR — Security Orchestration, Automation and Response: automates repetitive response tasks.

SOC — Security Operations Center: the team and tools that monitor and respond to threats.

Social engineering — Manipulating people into giving access or information.

SPF — Email authentication listing which servers may send mail for a domain.

SPL — Search Processing Language used in Splunk.

Sysmon — A free Microsoft tool that adds detailed endpoint logging.

TCP — Reliable, connection-oriented transport protocol.

Threat hunting — Proactively searching for attackers that evaded automated detection.

Threat intelligence — Information about attackers, their tools and their indicators.

TLS — Protocol that encrypts data in transit (used by HTTPS).

Triage — Quick assessment to decide the seriousness and next step for an alert.

True positive — An alert that correctly identified a real threat.

TTP — Tactics, Techniques and Procedures: the behavior patterns of an attacker.

UDP — Fast, connectionless transport protocol.

Vulnerability — A weakness that could be exploited.

WAF — Web Application Firewall: protects web apps from attacks like SQL injection.

Zero trust — A model that never trusts by default and always verifies.

Index

A

Alert fatigue, 36-37
Antivirus, 20, 30-31
ATT&CK, MITRE, passim
Authentication, 15, 30-32, 44
Authorization, 13, 23, 30-31, 45, 82-83

B

Beaconing, 48, 51-53, 64
Blue team, 14, 16, 60, 70, 72, 74, 87
Botnet, 15, 31
Brute force, 14, 24, 31, 36, 39, 41, 48, 50, 52, 63, 65, 76

C

CIA triad, 13, 15, 76
Command and control (C2), 23, 48-49, 51-52, 64, 72-73, 87
Containment, 18, 40, 42, 82, 89
CTF, 60-61, 87
CVE and CVSS, 31
Cyber Kill Chain, 47-49, 70
CyberChef, 30, 45, 64, 87

D

Defanging, 44-45, 86, 89
Defense in depth, 30-31
DFIR, 15, 82-83, 88
DHCP, 20, 23, 25, 32, 53
DKIM, SPF, DMARC, 23, 44-45, 89
DNS, passim
DNS tunneling, 52-53, 76

E

EDR, 17-18, 30-31, 35, 40, 64, 82
Encryption, passim
Event IDs (Windows), 27-29, 36, 41, 58, 64, 69, 76, 85

F

Firewall, 17-18, 20, 24, 30, 35, 40, 76

H

Hashing, 13, 30-32, 44, 47, 49, 76, 86, 89
Home lab, 35, 57-59, 70
HTTP and HTTPS, 23-24, 30, 51-52

I

IDS and IPS, 18, 24, 30, 76
Incident response, 14-15, 39-41, 69, 75, 79
Indicators of compromise (IOC), 47, 49
Interview questions, passim

L

Lateral movement, 41, 48, 63, 76
Least privilege, 30, 32
LetsDefend, 45, 60, 70, 75, 79, 87
Linux, 19, 25-26, 28, 35, 57, 60-61, 69, 75, 85, 88

M

Malware, passim
MFA, 13, 30-31, 40, 63, 76
MITRE tactics and techniques, 47-50, 70, 76

N

NAT, 22
Naukri and LinkedIn, 64, 70, 75, 77, 79, 89
NIST, 40-42, 82, 88

O

OSI model, 22, 25, 69, 82

P

Persistence, 27-29, 48-49
Phishing, passim
Playbook, 17, 40-42, 80-81, 89
Port scan, 22-23, 25, 51, 53, 58
Ports (common), 24
PowerShell, 27-28, 30-31, 49, 64, 85-86

R

Ransomware, 13-15, 24, 31, 39, 42, 48-49
Red team, 14, 16, 58-59, 82, 84, 88
Resume, 64, 67, 70, 75, 77-78, 89

S

Severity levels, 31, 39-40

SIEM, passim
SOAR, 18, 20
SOC tiers, passim
Splunk, passim
Sysmon, 27-29, 58, 64, 75, 85, 88

T

TCP three-way handshake, 23-25, 51-52, 69, 76
Threat intelligence, 17-18, 33, 47, 49, 69, 82, 87
Triage, passim
True and false positives, 18-19, 39, 41-42, 63-64, 76, 89
TryHackMe, 25, 45, 49, 60-61, 69-70, 75, 87, 89

U

UDP, 23-24, 76

V

VirusTotal, 18, 30, 44, 47, 50, 61, 63, 87

W

Wazuh, 18, 35, 37-38, 57-58, 75, 88
Windows, passim
Wireshark, 51-53, 61, 69, 75, 79, 88

Z

Zero trust, 30

This page intentionally left blank

A Message to Readers

Thank you for reading *Zero to SOC* to the end. Finishing a book like this means you have already done something many people only plan: you invested your time in your future.

What to do next, this week:

- 1 Pick one lab or room and finish it before the weekend.
- 2 Write your first short investigation report using the Alert, Triage, Investigate, Verdict, Action, Lesson format.
- 3 Set up or plan your home lab, even if it starts with one virtual machine.
- 4 Update your resume and LinkedIn with what you have learned so far.

Keep it honest and ethical. Only test what you own or have permission to test, protect other people's data, and report vulnerabilities responsibly. Trust is the real currency of this profession.

Verify before you rely. Prices, free offers, certifications and tools change quickly; this book shows its sources so that you can check the latest details for yourself.

Pass it on. If this book helped you, share it with someone who is starting out, complete and unmodified, and credit the author. When you land your first role, help the next person. That is how a community of defenders grows.

There will be setbacks, and there will also be a day when an alert fires, you investigate it calmly, you get it right, and you realize that you belong here. I hope that day comes soon for you.

Learn. Detect. Defend.

Suraj Wagh

India, 2026

Your first SOC job starts here.

Zero to SOC is a practical, budget-friendly roadmap for engineering and IT graduates, career changers and IT professionals who want to begin a career in cyber security. It teaches the skills a Tier 1 SOC analyst uses every day, shows you how to practice in a home lab, and guides you through certifications, your resume, interviews and your first 90 days.

INSIDE

- 18 chapters with diagrams, labs and video links
- A quiz after every chapter, with a full answer key
- A 16-week study plan and three sample investigation write-ups
- Cheat sheets, glossary, index and reference list

ABOUT THE AUTHOR

Suraj Wagh works in an IT company in India. This book gives beginners a clear, honest and affordable path into security operations.

LEARN. DETECT. DEFEND.

© 2026 Suraj Wagh. All rights reserved.

Free to share, complete and unmodified. See the terms inside.